CASE STUDY

E-Commerce Threats: The Public Record, 1999 to 2026

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

Most people who defend an online store never see the attacker. They see the symptoms: a call from the card brands about a common point of purchase, a chargeback spike nobody can explain, a support ticket from a shopper whose card was used somewhere else the week after checkout, a small JavaScript file that is a few lines longer than it was yesterday. The payments engineer, the platform admin patching Magento on a Friday night, the fraud analyst tuning velocity rules and the small-shop owner who just wants the plugin to work all stand on the same front line. This study reads twenty-seven years of that front line against the records that survive: SEC filings, Justice Department releases, a Senate staff report, CISA and CERT/CC advisories, two UK Information Commissioner's penalty notices, NVD and KEV records, PCI Security Standards Council publications, central-bank fraud data, and the vendor research that fills the gaps the regulators leave.

The record shows four things clearly. First, the target moved from the card file to the checkout page. The big breaches of 2005 to 2014 took card data from where it was stored or swiped: TJX's transaction systems, Heartland's processing network, Target's and Home Depot's point-of-sale terminals (Confirmed [3][5][7][8]). From 2018 the loss shifts to the browser, where a modified script copies what the shopper types: British Airways' own JavaScript file in 2018, a third-party chat bot on Ticketmaster UK's payment page the same year, a self-hosted analytics tracker on a Brazilian checkout in October 2026 (Confirmed [12][13]; Reported [21]). The Federal Reserve's data show why: as chip cards cut in-person fraud between 2015 and 2016, remote card fraud rose from $3.40 billion to $4.57 billion (Confirmed [96]).

Second, the way in was usually somebody else's key. A Swissport employee's credentials on a Citrix gateway without multi-factor authentication opened British Airways; a third-party vendor's user name and password opened Home Depot; Target's attackers reportedly came through an HVAC contractor (Confirmed [12][8]; Reported [7]). Third, the commerce platforms themselves became the mass entry point. CISA's Known Exploited Vulnerabilities catalog holds six Adobe Commerce and Magento entries from 2022 to 2026, three of

them added between September and October 2026, and none for WooCommerce, PrestaShop or Shopify (Confirmed [23]). In all three cases Sansec documents, exploitation outran the vendor's priority rating: CosmicSting under attack twelve days after the fix, SessionReaper probing 81 percent of stores within ten days of the first attack, and PolyShell mass-exploited about four months before the production-line bulletin that said Adobe knew of no exploits (Reported [26][28][29]; Confirmed [31]; the gaps are computed, Inferred). Fourth, the rules caught up late and the bill landed unevenly. PCI DSS requirements 6.4.3 and 11.6.1, which make merchants authorize and watch the scripts on their payment pages, became mandatory only after 31 March 2025, more than six and a half years after British Airways (Confirmed [63]). In US debit, merchants absorbed 49.9 percent of fraud losses in 2023 and 65.1 percent of card-not-present losses, against 38.3 percent of all losses in 2011 (Confirmed [95]).

> Evidence grade: the breaches, penalties, filings, statutes, standards and vulnerability records are **Confirmed** from SEC, DOJ, ICO, FTC, court, CISA, CERT/CC, NVD, PCI SSC, Federal Reserve, ECB and vendor primaries. Victim counts and exploitation rates that come from one security vendor's crawler, figures relayed by a secondary source, and every industry loss estimate are **Reported** and attributed. The library's own data checks are **Demonstrated** where this study counted or searched the data. Every ATT&CK, CWE, CAPEC, D3FEND and F3 mapping choice is this study's reading of the record and is **Inferred** unless the MITRE page itself carries the procedure.

Key facts at a glance

Field	Value
Period	December 1999 (CD Universe extortion) to November 2026 (PrestaShop VU#385711, 9 Nov 2026, after the Revolve 8-K and the Convertr skimmer in late October) [1][19][21][40]
Largest card-theft records	Gonzalez ring: more than 40 million card numbers from nine US retailers (DOJ, 5 Aug 2008) [4]; Target: about 40 million card accounts plus personal data for up to 70 million customers (Senate staff, 26 Mar 2014) [7]; Home Depot: custom malware on self-checkout and about 53 million email addresses (6 Nov 2014) [8]
Largest regulator penalty	British Airways, GBP 20m (16 Oct 2020), down from a proposed GBP 183.39m; Ticketmaster UK, GBP 1.25m (13 Nov 2020) [12][13]
How long skimmers ran	BA: script change live 21 Aug to 5 Sep 2018 (15 days), attacker active 22 Jun to 5 Sep [12]; Ticketmaster UK: February to 23 June 2018 [13]
KEV record for commerce platforms	Six Adobe Commerce/Magento entries (CVE-2022-24086, CVE-2024-34102, CVE-2025-54236, CVE-2026-75650, CVE-2026-71362, CVE-2026-48356) plus SAP Commerce Cloud CVE-2019-0344 and Sitecore CVE-2025-53690 (Experience Commerce among the affected products, added 4 Sep 2025); none for WooCommerce, PrestaShop or Shopify (catalog 2026.11.10) [23]
Fix to first exploitation	CosmicSting 12 days (11 to 23 Jun 2024); SessionReaper 43 days (9 Sep to 22 Oct 2025); PolyShell exploited in March 2026, production bulletin 14 Jul 2026 (Reported [26][28][29]; Confirmed [31]; gaps Inferred)
The standard	PCI DSS 6.4.3 (payment page script management) and 11.6.1 (change and tamper detection) required after 31 Mar 2025 [63]
Losses	Nilson: worldwide gross card fraud $33.83 billion in 2023, all channels (Reported [87]); Federal Reserve: card-not-present was 54.3 percent of US covered-issuer debit fraud losses in 2023 [95]
ATT&CK objects	FIN6 G0037 carries the alias "Magecart Group 6"; FIN5 G0053, FIN7 G0046 and FIN8 G0061 used point-of-sale malware; no ATT&CK campaign object covers any incident in this study [106][107][114]

Key findings

- **The loss moved from the card file to the checkout page.** TJX, Heartland, Target and Home Depot lost card data from stored, processed or swiped records; BA, Ticketmaster UK and the Magento waves lost it in the shopper's browser (Confirmed [3][5][7][8][12][13]; Reported [26][35]). Chip cards pushed fraud online: in-person card fraud fell from $3.68 billion to $2.91 billion between 2015 and 2016 while remote fraud rose from $3.40 billion to $4.57 billion (Confirmed [96]).
- **Third-party access was the front door.** BA, Home Depot and, by press accounts, Target were entered with a supplier's or contractor's credentials; BA's gateway had no multi-factor authentication (Confirmed [12][8]; Reported [7]).
- **Third-party code was the side door.** A chat bot on Ticketmaster UK's payment page, the polyfill.io domain after its sale, and Convertr's analytics tracker all carried code the merchant did not write into pages the merchant served (Confirmed [13][15][17]; Reported [16][21]).

- **Magento is the commerce platform of the KEV catalog.** Six of the commerce-platform entries in KEV are Adobe Commerce or Magento; the others found are SAP Commerce Cloud CVE-2019-0344 and Sitecore CVE-2025-53690, which covers Sitecore Experience Commerce (Confirmed [23]). Three of the six were added in September and October 2026 (Confirmed [23]).
- **A patch is not a cleanup.** Sansec reports CosmicSting attackers stole the store's crypt key, so patching without key rotation left stores exposed, and it found patched stores still infected by the 2025 to 2026 loader campaign (Reported [26][35]).
- **Vendor bulletins lagged the attackers.** CosmicSting shipped at low priority, SessionReaper at priority 2, and APSB26-73 said Adobe was not aware of exploits in the wild four months after Sansec's PolyShell mass-attack reports (Reported [26][28][29][30]; Confirmed [31]).
- **Regulators fined the merchant, not the attacker.** The ICO's notice describes the BA attacker as unidentified, and its penalty fell about 89 percent from proposal to final notice (Confirmed [12]; the percentage is computed, Inferred). ATT&CK's FIN6 entry cites reporting on the BA and Newegg incidents (Confirmed [106]).
- **The fraud bill is shifting toward merchants and cardholders.** US debit fraud losses rose from 7.8 to 17.6 basis points of value between 2011 and 2023, the merchant share from 38.3 to 49.9 percent and the cardholder share from under 1.8 to 21.8 percent (Confirmed [95]).

Top recommendations

1. **Inventory, authorize and watch every script on your payment pages.** That is PCI DSS 6.4.3 and 11.6.1, required since 31 March 2025 (Confirmed [63][66]). The ICO said file-integrity monitoring of the kind PCI DSS v3.2.1 already asked for would have detected BA's script change (Confirmed [12]). The library's File Integrity Monitoring and Software Inventory pages cover the countermeasures (Confirmed [114]).
2. **Put multi-factor authentication on every remote path a supplier can use.** BA's Citrix gateway lacked it, Home Depot's attackers entered with a vendor's user name and password and then acquired elevated rights, and Backoff's operators brute-forced remote desktop logins (Confirmed [12][8][9]). The library's Multi-factor Authentication page covers the countermeasure (Confirmed [114]).
3. **Patch Adobe Commerce and Magento on the KEV clock, then clean up.** Rotate the crypt key after CosmicSting-class flaws, search CMS blocks and pages for injected loaders, and assume a patched store can still be infected (Reported [26][35]; Confirmed [23]).
4. **Never log what you would not want stolen.** BA's attacker reached plaintext log files holding about 108,000 cards, and the ICO cited PCI DSS requirement 3.1 on retention because card data including CVV was being logged (Confirmed [12]).
5. **Treat CSP and SRI as layers, not answers.** W3C CSP can limit where a page sends data only when the policy is strict, SRI covers only script and link elements, and Microsoft and Sansec report server-side injection that a browser policy cannot see (Confirmed [104][105]; Reported [44][45]).
6. **Defend logins and checkout against automation.** The New York Attorney General ranks bot detection first, then multi-factor authentication, passwordless sign-in and compromised-password checks, with re-authentication at purchase (Confirmed [46]). Stripe's card-testing guidance adds rate limits, velocity rules and secret-key hygiene (Confirmed [48]).

7. **Know your third-party script owners.** Remove dependencies whose ownership changed, as polyfill.io's did in February 2024, and mirror or pin what you keep (Confirmed [15][17]; Reported [16]).
8. **Rehearse disclosure.** SEC Form 8-K Item 1.05 has applied since 18 December 2023, generally four business days after a materiality determination; Revolve's 8-K of October 2026 reported possible card-data theft voluntarily under Item 8.01 and said it did not expect a material impact (Confirmed [76][19]).

Scope and method

This study covers threats to online and card-based retail from the CD Universe extortion of December 1999 to the incidents the Intelligence Hub indexed in early November 2026. It reads the record in six parts: the breach and fraud timeline (Parts 1 and 2); the threat classes, from web skimming to fake shops (Part 3); the platform vulnerabilities and the KEV record (Part 4); the standards and regulatory record (Part 5); the economics (Part 6); and the defender view and MITRE mappings (Parts 7 and 8). Retail incidents against refrigeration and building controllers belong to an industrial-control lens, not this one, and are left out.

Home studies. The CD Universe record of 1999 to 2000 belongs to The Dot-Com Era: Cyber Events, 1994 to 2003, the home for it and for the Egghead.com and Gorshkov and Ivanov records; this study summarizes CD Universe in one paragraph (Part 2.1). The carding markets of the 2000s (Shadowcrew and the Max Butler case) belong to Cybercrime and Hacktivism in Four Books. Package-registry supply-chain attacks belong to npm Supply Chain Attacks; this study covers third-party scripts loaded into payment pages. PHP runtime flaws under PHP storefronts belong to PHP2Shell and the October 2026 Attack Wave. This study is the home for the Magento and Adobe Commerce exploitation waves of 2022 to 2026 as a series. PolyShell (CVE-2026-48356) has its own study, Magento and Adobe Commerce, CVE-2026-48356: Lab-Verified Exposure and Fix, which is the home for that flaw's exposure, fix and lab evidence; this study summarizes PolyShell in one paragraph (Part 4.4).

Every source was opened on 11 November 2026. The Intelligence Hub feed served as an index of 2025 and 2026 events; its rows are an index, not a source, and every claim drawn from it rests on the primary or press page it pointed to. Quotations are kept to a few words. Tradecraft is described at the level the advisories use: technique names and identifiers, never commands, payloads, skimmer code, loader strings or exploit details. Several primaries could not be opened and are listed in Part 2.12 as not checked; no claim rests on them. The SEC, FTC and Adobe security-bulletin pages refuse automated link checkers, so their addresses are given as plain text in the Sources table.

Grade	Meaning
Confirmed	A primary source was opened: an SEC filing, a DOJ release or court opinion, a Senate committee report, a regulator's penalty notice, decision or rule, a CISA, US-CERT, CERT/CC or FBI advisory, an NVD or KEV record, a vendor's own security bulletin or statement about its own systems, a standards body's publication about its own standard, central-bank or agency statistics, or the MITRE record and the library's data files
Reported	Known through a secondary source or one party's account of others: press coverage, a security vendor's telemetry or research about third-party victims (Sansec, SRLabs, Microsoft, F5 Labs, Akamai), industry loss reports and forecasts (Nilson, LexisNexis, Juniper), or a primary that relays a third party's figure
Demonstrated	This study searched or counted the library's own data and shows the result

Grade	Meaning
Inferred	This study's own reasoning from the cited facts, including computed gaps and every ATT&CK, CWE, CAPEC, D3FEND and F3 mapping choice, labelled where it appears

Where sources disagree on a number or a date, the study gives both and says which the primary record supports. Dates are given as each source states them. The passage on what is overstated and what is understated sits under Cross-cutting themes.

Part 1: the timeline

One row per dated event or report.

Date	Event	Grade	Source
25 Dec 1999 to 9 Jan 2000	An extortionist calling himself "Maxim" claims about 300,000 card numbers from CD Universe, demands US$100,000 and posts card data after refusal; up to 25,000 numbers distributed	Reported	[1]
Jul 2005	Intruder first accesses TJX systems; further access later in 2005 and from mid-May 2006 to mid-January 2007	Confirmed	[3]
Sep 2006	PCI Security Standards Council formed by American Express, Discover, JCB International, MasterCard and Visa Inc.	Confirmed	[57][58]
18 to 27 Dec 2006	TJX finds suspicious software (18 Dec), notifies law enforcement (22 Dec), determines customer data stolen (27 Dec)	Confirmed	[3]
17 Jan 2007	TJX announces an unauthorized intrusion into systems that process and store customer transaction data	Confirmed	[2]
2008	Heartland Payment Systems breached within its processing system	Confirmed	[5]
2008 to 2009	Wyndham hotels breached three times; card data of over 619,000 consumers taken	Confirmed	[11]
5 Aug 2008	DOJ charges eleven defendants, including Albert "Segvec" Gonzalez, over nine retailers and more than 40 million card numbers	Confirmed	[4]
1 Oct 2008	PCI DSS v1.2 generally available; WEP sunset set for June 2010	Confirmed	[58]
20 Jan 2009	Heartland discloses malicious software that compromised data crossing its network	Confirmed	[5]
8 Jan 2010	Heartland and Visa announce a settlement of up to $60 million for Visa issuers	Confirmed	[6]
Aug 2011	PCI DSS Tokenization Guidelines v2.0	Confirmed	[69]
13 Oct 2011	SEC CF Disclosure Guidance Topic No. 2 on cyber risk disclosure	Confirmed	[75]
4 Feb 2013	Visa sets a US ATM EMV liability shift for 1 Oct 2017	Confirmed	[73]
Oct 2013	Backoff point-of-sale malware first seen	Confirmed	[9]

Date	Event	Grade	Source
27 Nov to 18 Dec 2013	Cards used in Target's US stores exposed	Confirmed	[7]
30 Nov and 2 to 3 Dec 2013	FireEye alerts at Target reportedly fire without response	Reported	[7]
12 to 19 Dec 2013	DOJ contacts Target (12 Dec); Target confirms about 40 million card accounts (19 Dec)	Confirmed	[7]
10 Jan 2014	Target discloses personal data for up to 70 million customers	Confirmed	[7]
26 Mar 2014	Senate Commerce majority staff report on the Target breach	Confirmed	[7]
31 Jul 2014	US-CERT TA14-212A on Backoff	Confirmed	[9]
22 Aug 2014	TA14-212A Overview revised; Secret Service estimates over 1,000 US businesses affected	Confirmed	[9]
6 Nov 2014	Home Depot: vendor credentials, custom malware on self-checkout, about 53 million email addresses	Confirmed	[8]
2015	Magecart groups active from 2015, per PCI SSC	Reported	[68]
24 Aug 2015	Third Circuit affirms the FTC's authority over inadequate cybersecurity in FTC v. Wyndham	Confirmed	[11]
13 Oct 2015	FBI warns EMV does not stop card-not-present fraud	Confirmed	[72]
9 Dec 2015	FTC settlement with Wyndham: 20 years of annual PCI DSS audits	Confirmed	[10]
2015 to 2016	US in-person card fraud falls from $3.68 billion to $2.91 billion; remote card fraud rises from $3.40 billion to $4.57 billion	Confirmed	[96]
2016	Nilson: worldwide gross card fraud $22.80 billion	Reported	[82]
Jan 2016	FIN8 active against hospitality and retail from at least this date	Confirmed	[107]
31 Oct 2016	Europol's first European-wide e-commerce fraud action: 42 arrests	Confirmed	[77]
6 to 16 Jun 2017	Europol eCommerce Action 2017: 76 arrests in 26 countries	Confirmed	[78]
25 Oct 2017	PCI 3DS Core Security Standard released	Confirmed	[70]
Feb to 23 Jun 2018	Ticketmaster UK's payment page carries a compromised third-party chat bot script	Confirmed	[13]
May 2018	A Twitter user's warning about the chat bot file is dismissed	Confirmed	[13]
4 to 15 Jun 2018	Europol eComm 2018: 95 arrests in 28 countries	Confirmed	[79]
22 Jun 2018	BA attacker enters through a Swissport employee's Citrix credentials	Confirmed	[12]
26 Jul 2018	BA attacker reaches plaintext card logs (about 108,000 cards)	Confirmed	[12]

Date	Event	Grade	Source
21 Aug to 5 Sep 2018	BA's modified JavaScript sends card data to BAways.com; a third party alerts BA on 5 Sep; ICO notified 6 Sep	Confirmed	[12]
4 Jul 2019	ICO Notice of Intent proposes GBP 183.39m against BA	Confirmed	[12]
1 Aug 2019	PCI SSC and RH-ISAC joint bulletin on online skimming	Confirmed	[67]
30 Oct 2019	Europol: 60 e-commerce fraudsters arrested in an international operation	Confirmed	[80]
2019	Nilson: worldwide gross card fraud $28.65 billion	Reported	[83]
9 Jan 2020	PCI SSC calls Magecart an umbrella term for several groups	Reported	[68]
2020	ICO fines DSG Retail GBP 500,000	Confirmed	[74]
11 to 14 Sep 2020	"Cardbleed": skimmers injected into 1,904 Magento 1 stores, later revised to 2,806	Reported	[14]
16 Oct 2020	ICO fines BA GBP 20m	Confirmed	[12]
13 Nov 2020	ICO fines Ticketmaster UK GBP 1.25m	Confirmed	[13]
2020	Nilson: $28.58 billion	Reported	[84]
22 Jan 2021	FTC brings the first BOTS Act cases	Confirmed	[51]
17 Jun 2021	PCI SSC moves PCI DSS v4.0 to Q1 2022	Confirmed	[59]
Jun 2021	FIN8 switches from point-of-sale targeting to ransomware	Confirmed	[107]
5 Aug 2021	F5 Labs describes buy-now-pay-later fraud scenarios	Reported	[55]
2021	Nilson: $32.34 billion; BogusBazaar fake-shop orders begin	Reported	[85][56]
15 to 16 Feb 2022	CVE-2022-24086 added to KEV (15 Feb), published by NVD (16 Feb)	Confirmed	[23][24]
31 Mar 2022	PCI DSS v4.0 published	Confirmed	[60]
23 May 2022	Microsoft reports the shift to obfuscated and spoofed-analytics skimmers	Reported	[45]
Jun 2022	Sansec: about 64 percent of 234 sampled skimming attacks server-side	Reported	[44]
1 Aug 2022	NVD publishes PrestaShop CVE-2022-31181	Confirmed	[39]
15 Sep 2022	CFPB study of buy-now-pay-later lending	Confirmed	[54]
15 Nov 2022	Eras Tour onsale: 3.5 billion system requests and "bot attacks"	Confirmed	[52]
2022	Nilson: $33.45 billion; LexisNexis: $3.85 per $1 of fraud for US e-commerce	Reported	[86][89]

Date	Event	Grade	Source
22 to 27 Mar 2023	WooCommerce Payments flaw found (22 Mar), auto-patched, customer reports of potential exploits by 27 Mar	Confirmed	[38]
26 Jun 2023	Juniper forecasts more than $362 billion in merchant online payment fraud, 2023 to 2028	Reported	[93]
26 Jul 2023	SEC adopts Form 8-K Item 1.05	Confirmed	[76]
22 Dec 2023	Europol digital skimming action notifies 443 compromised merchants	Confirmed	[81]
2023	Nilson: $33.83 billion; Fed: US debit fraud 17.6 basis points	Reported; Confirmed	[87][95]
H1 2023	EEA card fraud on EEA-issued cards EUR 633 million; 82 percent remote	Confirmed	[98]
Feb 2024	polyfill.io domain and GitHub account sold	Reported	[16][17]
29 Feb 2024	Cloudflare launches a cdnjs polyfill mirror	Confirmed	[15]
Apr 2024	BogusBazaar: about 22,500 of 75,000-plus domains active	Reported	[56]
11 Jun 2024	PCI DSS v4.0.1 announced; Adobe ships the CosmicSting fix	Confirmed; Reported	[61][26]
13 Jun 2024	NVD publishes CVE-2024-34102 (CosmicSting)	Confirmed	[25]
18 Jun 2024	About 75 percent of Magento stores still unpatched, per Sansec	Reported	[26]
23 Jun 2024	First CosmicSting attacks in the wild	Reported	[26]
25 to 26 Jun 2024	polyfill.io serves malicious code; Cloudflare rewrites links; NVD publishes CVE-2024-38526; Adobe raises CosmicSting priority	Confirmed; Reported	[17][18][16][26]
17 Jul 2024	CVE-2024-34102 added to KEV	Confirmed	[23]
20 Aug 2024	PCI SSC: 51 of 64 new v4.x requirements take effect 31 Mar 2025	Confirmed	[62]
30 Sep 2024	SAP Commerce Cloud CVE-2019-0344 added to KEV	Confirmed	[23]
14 Oct to 13 Nov 2024	CosmicSting waves: more than 2,000 stores, then about 3,000 more	Reported	[26]
2024	FTC: over $12.5 billion consumer fraud losses; IC3: $16.6 billion; Nilson: US cards 41.87 percent of worldwide losses	Confirmed; Reported	[101][103][88]
30 Jan 2025	PCI SSC moves 6.4.3, 11.6.1 and 12.3.1 out of SAQ A, replaced by an eligibility criterion	Confirmed	[64]
28 Feb 2025	PCI SSC FAQ 1588 on the new SAQ A criterion	Confirmed	[65]
10 Mar 2025	PCI SSC information supplement on payment page security and e-skimming	Confirmed	[66]

Date	Event	Grade	Source
31 Mar 2025	6.4.3 and 11.6.1 become required; Executive Order 14254 on BOTS Act enforcement	Confirmed	[63][53]
Jul 2025	Magento CMS-block loader campaign begins	Reported	[35]
4 Sep 2025	Sitecore CVE-2025-53690, whose affected products include Sitecore Experience Commerce, added to KEV	Confirmed	[23]
9 Sep 2025	Adobe APSB25-88 fixes SessionReaper (CVE-2025-54236)	Confirmed	[27]
19 Sep 2025	Fewer than one in three stores patched, per Sansec	Reported	[28]
22 to 26 Oct 2025	SessionReaper attacks begin (22 Oct); KEV entry and Adobe priority 1 (24 Oct); 49 percent of stores hit (26 Oct)	Reported; Confirmed	[28][23]
1 Nov 2025	81 percent of stores visited by SessionReaper attackers, per Sansec	Reported	[28]
19 Feb 2026	Court of Appeal rules for the ICO in the DSG Retail case	Confirmed	[74]
17 Mar 2026	Sansec discloses PolyShell (CVE-2026-48356) with no production patch	Reported	[29]
19 Mar 2026	NVD publishes WooCommerce Wholesale Lead Capture CVE-2026-27540	Confirmed	[41]
30 Mar 2026	PolyShell mass wave: 471 stores in one hour	Reported	[30]
12 May 2026	Magento 2.4.9 with the PolyShell fix released	Reported	[29]
4 to 17 Jun 2026	Peak of exploitation attempts against CVE-2026-27540	Reported	[42]
14 Jul 2026	Adobe APSB26-73 fixes PolyShell, priority 2, "not aware" of exploits	Confirmed	[31][32]
11 Aug 2026	NVD publishes CVE-2026-71362	Confirmed	[33]
7 to 8 Sep 2026	CVE-2026-75650 published (7 Sep) and added to KEV (8 Sep)	Confirmed	[34][23]
24 Sep 2026	CVE-2026-71362 added to KEV	Confirmed	[23]
7 Oct 2026	DSG Retail proceedings close with a GBP 200,000 payment	Confirmed	[74]
24 Oct 2026	Sansec: CMS-block loader on 953 stores since July 2025	Reported	[35][36]
24 to 27 Oct 2026	Skimmer appended to Convertr's analytics tracker, removed by 27 Oct	Reported	[21]
27 Oct 2026	CVE-2026-48356 added to KEV	Confirmed	[23]
28 Oct 2026	Drupal Commerce Core flaw reported exploited; Iris Ohyama finds a suspicious file on a cloud service	Reported	[43][22]

Date	Event	Grade	Source
30 Oct 2026	Revolve Group files an 8-K (Item 8.01): an unauthorized actor may have obtained saved card data "through automated means"; Akamai's 2026 fraud report published	Confirmed; Reported	[19][47]
9 Nov 2026	CERT/CC VU#385711 on PrestaShop CVE-2026-124916	Confirmed	[40]
10 Nov 2026	KEV catalog version 2026.11.10	Confirmed	[23]

Part 2: the breach record

2.1 CD Universe, 1999 to 2000 (summary; home study is the dot-com era study)

WIRED, citing The New York Times, reported that an extortionist using the alias "Maxim" claimed to have stolen about 300,000 card numbers from CD Universe, demanded US$100,000, and after the company refused posted card data on a website from Christmas Day 1999; up to 25,000 numbers were distributed and the FBI was investigating (Reported [1]). The pattern of the decade that followed, steal the card file and then sell it or demand money for silence, is visible in this first case (Inferred). The Dot-Com Era: Cyber Events, 1994 to 2003 is the home for this record and carries it from eUniverse's own SEC filing.

2.2 TJX and the Gonzalez ring, 2005 to 2008

TJX announced on 17 January 2007 an unauthorized intrusion into the systems that process and store customer transaction data for its US and Puerto Rico chains and its Canadian stores, with possible exposure in the UK, Ireland and at Bob's Stores (Confirmed [2]). Its 10-K adds the chronology. TJX found suspicious software on 18 December 2006, notified law enforcement on 22 December, honored a Secret Service request for confidentiality, and first determined on 27 December that customer data had been stolen (Confirmed [3]). The intruder had first accessed TJX systems in July 2005, again later in 2005, and from mid-May 2006 to mid-January 2007, and TJX believed the intruder had access to the decryption tool for its encryption software (Confirmed [3]). That is about seventeen months from first access to discovery (Inferred).

On 5 August 2008 DOJ charged eleven defendants, including Albert "Segvec" Gonzalez, in the hacking of nine major US retailers and the theft of more than 40 million card numbers (Confirmed [4]). DOJ alleged that the ring went "wardriving" into the wireless networks of TJX, BJ's Wholesale Club, OfficeMax, Boston Market, Barnes & Noble, Sports Authority, Forever 21 and DSW; installed sniffer programs on card-processing networks; kept the data on encrypted servers in Eastern Europe and the US; and cashed out at ATMs with blank cards encoded with stolen data (Confirmed [4]). Gonzalez had been a Secret Service informant, and a related case charged a packet sniffer on Dave & Buster's cash register terminals (Confirmed [4]). The DOJ releases on Gonzalez's later indictment over Heartland and on his sentence were not opened (Part 2.12), so this study does not state those counts or the sentence. The carding market Gonzalez came from belongs to Cybercrime and Hacktivism in Four Books.

2.3 Heartland Payment Systems, 2008 to 2010

Heartland disclosed on 20 January 2009 a breach within its processing system during 2008 (Confirmed [5]). Visa and MasterCard alerted it to suspicious activity; the forensic investigation found malicious software that compromised data crossing Heartland's network; the company said the breach might be part of a widespread global cyber fraud operation and that it was cooperating with the Secret Service and DOJ (Confirmed [5]). On 8 January 2010 Heartland and Visa announced a settlement of up to $60 million for Visa issuers over "the 2008 criminal breach" (Confirmed [6]). The case shows the card brands acting as the detection system: the processor learned of its own breach from Visa and MasterCard (Confirmed [5]; the reading is Inferred).

2.4 Wyndham and the FTC, 2008 to 2015

Hackers breached Wyndham three times in 2008 and 2009, taking payment card data of more than 619,000 consumers and causing at least $10.6 million in fraudulent charges (Confirmed [11]). The Third Circuit's opinion of 24 August 2015 affirmed that the FTC may pursue inadequate cybersecurity as an unfair practice (Confirmed [11]). The FTC's settlement of 9 December 2015 requires a security program for cardholder data, annual audits conforming to PCI DSS for 20 years, and a breach assessment to the FTC within 10 days of any breach of more than 10,000 card numbers (Confirmed [10]). The settlement wrote the industry standard into a federal order (Inferred).

2.5 Target, 2013

The Senate Commerce Committee's majority staff report of 26 March 2014 sets out what the report states Target confirmed. The attack ran in November and December 2013; on 19 December Target confirmed that about 40 million card accounts used in its US stores between 27 November and 18 December were exposed; Target said DOJ had contacted it on 12 December; on 10 January 2014 it disclosed personal data for up to 70 million customers, up to 110 million in total; and Target's CEO confirmed point-of-sale malware (Confirmed [7]).

The rest of the familiar story comes from the press accounts the report relays, and the report says it relies on media reports and expert analyses. By those accounts the attackers first entered with credentials stolen from HVAC contractor Fazio Mechanical Services, installed RAM-scraping malware that Brian Krebs described as a tailored BlackPOS variant, and set off FireEye alerts on 30 November and 2 to 3 December 2013 that were not acted on, per Bloomberg Businessweek; and, by those accounts, the data was moved to a server in Eastern Europe (Reported [7]). None of these three points is Target's own statement in the opened record, and BlackPOS is not an ATT&CK software object (Confirmed [114]).

2.6 Home Depot and Backoff, 2013 to 2014

US-CERT's alert TA14-212A of 31 July 2014 described Backoff, point-of-sale malware first seen around October 2013 (Confirmed [9]). Attackers gained access by brute-forcing remote desktop logins; the malware scraped memory for track data, logged keystrokes, communicated with its server over HTTP POST and injected itself into explorer.exe; variants 1.4, 1.55 and 1.56 were recorded (Confirmed [9]). The alert's Overview, revised on 22 August 2014, adds the Secret Service estimate that more than 1,000 US businesses were affected, and seven point-of-sale providers confirmed multiple clients affected (Confirmed [9]).

Home Depot's release of 6 November 2014 said criminals used a third-party vendor's user name and password to enter the perimeter, acquired elevated rights, and deployed unique, custom-built malware on self-checkout systems in the US and Canada (Confirmed [8]). Separate files with about 53 million email

addresses were also taken; the malware had not been seen before and was designed to evade antivirus; the company rolled out enhanced encryption and EMV chip-and-PIN (Confirmed [8]). The September 2014 release with the card count returned 404 and is not checked, so this study does not state the 56 million figure.

2.7 British Airways, 2018

The ICO's penalty notice of 16 October 2020 is the most detailed public record of a payment-page skimming case. An attacker was active in BA's systems from 22 June to 5 September 2018 (Confirmed [12]). Entry was through the compromised credentials of a Swissport employee on BA's Citrix Access Gateway, which did not require multi-factor authentication; the attacker broke out of the Citrix environment and moved through the network (Confirmed [12]). On 26 July the attacker reached plaintext log files holding payment card data for about 108,000 cards (Confirmed [12]). The attacker then edited a JavaScript file on britishairways.com so that card data was copied to the attacker-controlled domain BAways.com; the change was live from 21 August to 5 September, 15 days; a third party alerted BA on 5 September and BA notified the ICO on 6 September (Confirmed [12]).

About 429,612 individuals were potentially affected, about 244,000 of them with name, address, card number and CVV (Confirmed [12]). The Notice of Intent of 4 July 2019 proposed GBP 183.39m; the final calculation started at GBP 30m, fell 20 percent for mitigation to GBP 24m, and fell to GBP 20m under the ICO's Covid-19 policy, for infringing GDPR Articles 5(1)(f) and 32 (Confirmed [12]). The notice cites PCI DSS v3.2.1 requirements 10.5.5 and 11.5, file-integrity monitoring with weekly comparison of critical files, as measures that would have detected the script change, and requirement 3.1 on retention because card data including CVV was being logged (Confirmed [12]). The ICO did not identify the attacker. ATT&CK's FIN6 entry cites reporting on the BA and Newegg Magecart incidents under Data from Local System (Confirmed [106]); that attribution rests on the reporting ATT&CK cites, not on the regulator (Inferred). No Newegg primary was opened (Part 2.12).

2.8 Ticketmaster UK, 2018

The ICO fined Ticketmaster UK GBP 1.25 million on 13 November 2020 (Confirmed [13]). Ticketmaster had placed JavaScript for a chat bot from the third party Inbenta on pages including its payment page; an attacker inserted malicious code into that JavaScript; the breach ran from February 2018 to 23 June 2018; Ticketmaster notified 9.4 million data subjects in the EEA, 1.5 million of them in the UK (Confirmed [13]). Barclays said about 60,000 cards were compromised and Monzo replaced about 6,000; a Twitter user's May 2018 warning about the modified file was dismissed (Confirmed [13]). The lesson of the case is that a merchant answers for code it chose to load, not only for code it wrote (Inferred).

2.9 Cardbleed and the end of Magento 1, 2020

Sansec reported that over a weekend around 11 to 14 September 2020 a Magecart-style skimmer was injected into 1,904 Magento 1 stores, a figure it later revised to 2,806, about 3 percent of the Magento 1 base (Reported [14]). Magento 1 had reached end of life in June 2020; the access vector was unconfirmed, and Sansec suspected a Magento 1 remote code execution exploit offered on a forum for US$5,000 (Reported [14]). An unsupported platform with a live install base is a ready-made target list (Inferred).

2.10 polyfill.io, 2024

polyfill.io served a JavaScript compatibility library that many sites loaded directly from its domain. After the domain changed hands, Cloudflare launched a mirror on its cdnjs service on 29 February 2024, citing concerns raised by the community and the library's original author about the new owner (Confirmed [15]). Sansec reported that a company bought the domain and the GitHub account in February 2024, and that from 25 June the domain injected code into more than 100,000 embedding sites that redirected mobile visitors through a look-alike analytics domain, skipped administrators and evaded analytics (Reported [16]). Google blocked ads for e-commerce sites that used polyfill.io, and Namecheap put the domain on hold (Reported [16]).

Cloudflare said on 26 June 2024 that reports, corroborated by its own Page Shield data, showed polyfill.io injecting malicious JavaScript, and it turned on automatic rewriting of polyfill.io links to its mirror (Confirmed [17]). Cloudflare put the earliest malicious file it detected at 8 June, cited an estimate that the script ran on nearly 4 percent of websites, and did not rewrite responses that carried a Content Security Policy header (Reported [17]). NVD published CVE-2024-38526 on 26 June for pdoc, whose math output linked to polyfill.io, a CDN that the record says "has been sold and now serves malicious code"; pdoc 14.5.1 fixed it (Confirmed [18]). The payload was a redirect, not a card skimmer, so polyfill.io shows the third-party script risk rather than a card theft (Inferred). Supply-chain compromise through package registries, the neighboring problem, is covered in npm Supply Chain Attacks, and The Year 2024 in Intrusions places polyfill.io in that year's timeline.

2.11 The 2026 record: Revolve, Convertr and Iris Ohyama

Revolve Group's 8-K, filed 30 October 2026, reports unauthorized access to certain systems; an unauthorized actor may have obtained, "through automated means", the name, contact information, card number and expiration date of customers who had saved payment information in their online accounts; there was no operational disruption; the company filed under Item 8.01 and said it does not believe the incident will have a material impact (Confirmed [19]). The filing does not state the vector, and nothing in it shows skimming (Confirmed [19]). The Record reports state filings listing 127,200 affected people in Texas and 1,328 in Vermont (Reported [20]). The Intelligence Hub feed row that indexed the story, and The Record's URL, spell the company "Resolve"; the filing is Revolve's.

Sansec reported that a Brazilian Magecart group appended a card skimmer to the self-hosted Plausible analytics tracker that Convertr loaded on every checkout from 24 October 2026, capturing card data and Brazilian CPF taxpayer numbers; Sansec suspects entry through CVE-2026-8467 in an outdated Plausible install, unconfirmed; the skimmer was removed by 27 October (Reported [21]). The analytics script is the 2026 version of the 2018 chat bot (Inferred).

The Register reports that Iris Ohyama suspended its Iris Plaza online store after a suspicious file was found on a third-party cloud service on 28 October 2026, potentially exposing data on about 7.7 million customers, and that payment data was not stored there (Reported [22]). The company's own notice returned 403 and is not checked.

2.12 What the record does not show (not checked)

These primaries could not be opened on 11 November 2026, and no claim in this study rests on them: the DOJ releases on Gonzalez's 2009 indictment (Heartland, 7-Eleven, Hannaford) and 2010 sentence, and on the 2018 sentencing of two Russian nationals in the Heartland conspiracy; Home Depot's September 2014 release; the FTC's TJX settlement pages; the RiskIQ and Volexity research on Newegg, BA and Ticketmaster; the Interpol release on the 2020 Indonesian skimming arrests; Adobe's bulletins APSB22-12, APSB24-40, APSB25-88, APSB26-92 and APSB26-146 (the NVD records carry their references); Drupal's advisories for Commerce Core; EMVCo's 3-D Secure pages; the 1 October 2015 US point-of-sale liability shift date from a card-brand primary; the PCI DSS 1.0 release date; chargeback and first-party fraud volumes; and refund fraud. The New York Times article behind source [1] returned 403.

Part 3: the threat classes

3.1 Web skimming ("Magecart")

PCI SSC describes Magecart as an umbrella term for several criminal groups, active since 2015, that often compromise third-party libraries so that one compromise reaches many merchant sites (Reported [68]). Sansec treats the name as a synonym for web skimming and formjacking rather than one group, reports more than 70,000 compromised stores identified by 2022, and found about 64 percent of attacks in a June 2022 sample of 234 to be server-side; it put supply-chain attacks at under 1 percent of 2021 incidents (Reported [44]). Microsoft reported in May 2022 that skimmers moved to obfuscated scripts, spoofed analytics code and PHP hidden in images, that server-side injection can bypass a Content Security Policy, and called Magecart one notable campaign or group (Reported [45]). ATT&CK ties the name only to FIN6, whose associated names include "Magecart Group 6" (Confirmed [106]).

The record names three ways in. The merchant's own script is edited after an intrusion, as at BA (Confirmed [12]). A third-party script the merchant loads is altered at its source, as with the Inbenta chat bot, polyfill.io and the Convertr tracker (Confirmed [13][17]; Reported [21]). Or a platform flaw lets the attacker write into the store's content, as in the Magento waves where skimmers and loaders landed in CMS blocks (Reported [26][30][35]). The PCI SSC and the Retail and Hospitality ISAC's 2019 bulletin quotes research that one in five Magecart-infected stores is re-infected within days; the original study was not opened (Reported [67]). Europol's December 2023 action is the law-enforcement picture: 443 merchants notified that they had been unknowing points of compromise, in an action led by Greece with 16 other countries and the private partners Sansec and Group-IB (Confirmed [81]).

3.2 Point-of-sale malware and the FIN groups

Point-of-sale malware was the dominant card-theft class of 2013 to 2014: Backoff across more than 1,000 US businesses, the malware Target's CEO confirmed, and Home Depot's custom self-checkout malware (Confirmed [9][7][8]). ATT&CK carries several point-of-sale families and the groups that used them: RawPOS (S0169), in use since at least 2008 and attributed to FIN5 (G0053); FrameworkPOS (S0503), FIN6's; Pillowmint (S0517), FIN7's; and PUNCHTRACK (S0197) and the backdoor PUNCHBUGGY (S0196), FIN8's (Confirmed [114]). The library's mappings tie RawPOS, FrameworkPOS and PUNCHTRACK to Data from Local System (T1005) and Local Data Staging (T1074.001), and Pillowmint to T1005 (Demonstrated [114]); they tie FrameworkPOS also to Exfiltration Over Alternative Protocol, Process Discovery and Archive via Custom Method (Confirmed [114]). BlackPOS and Backoff are not ATT&CK software objects (Confirmed [114]).

The groups moved on. ATT&CK records FIN8 targeting hospitality and retail from at least January 2016 and switching from point-of-sale targeting to ransomware in June 2021 (Confirmed [107]), and the library's ATT&CK data records FIN7 using point-of-sale malware, running the front company Combi Security, and moving to big game hunting from 2020 (Confirmed [114]). The card-theft crews of the 2010s became ransomware operators of the 2020s (Inferred); the library's 2020 chronicle follows FIN6 into that record (Confirmed [114]).

3.3 Credential stuffing and account takeover

ATT&CK defines Credential Stuffing (T1110.004) as a sub-technique of Brute Force under Credential Access (Confirmed [111]). The New York Attorney General's business guide says the office compiled credentials for 17 companies and more than 1.1 million customer accounts that appeared compromised by credential stuffing, at online retailers, restaurant chains and food delivery services; the page shows no publication date (Confirmed [46]). Akamai's 2026 fraud report, as Help Net Security reports it, links 8.3 percent of account creation attempts in 2025 to suspected fraud, describes fake accounts used for welcome bonuses, card testing and hoarding limited stock, and rates 26.6 percent of logins in a July to August 2026 sample as high or critical risk (Reported [47]). OWASP's automated-threat catalog defines OAT-008 Credential Stuffing as mass login attempts to verify stolen credential pairs (Confirmed [50]). SessionReaper, Part 4, is the platform-level form of the same goal (Inferred): CISA's KEV entry describes customer account takeover through the Commerce REST API (Confirmed [23]).

3.4 Card testing

Stripe's documentation defines card testing, also called carding, enumeration or card checking, as validating stolen card data through scripted card setups or small payments; the merchant pays in disputes, higher decline rates and fees, and the mitigations are CAPTCHA, limits on access to the payment form, rate limits, velocity rules and hygiene for secret API keys, since a stolen key lets testers create payments directly (Confirmed [48]). OWASP's OAT-001 Carding is the same class: repeated payment authorization attempts to validate bulk stolen card data (Confirmed [49]). Akamai reports fake accounts created for card testing (Reported [47]). This study found no ATT&CK technique in the library's data for card testing (Demonstrated [114]); the library's F3 data carries it as F1012 (Part 8; Demonstrated [114]).

3.5 Scalping and inventory bots

The FTC brought the first cases under the 2016 BOTS Act on 22 January 2021 against three New York ticket brokers who used automated ticket-buying software, concealed their IP addresses and hundreds of fictitious Ticketmaster accounts to buy more than 150,000 tickets; the judgments exceeded US$31 million, with about US$3.7 million payable (Confirmed [51]). Ticketmaster said the Eras Tour onsale of 15 November 2022 drew 3.5 billion system requests, four times its previous peak, and "the staggering number of bot attacks", without a count; more than two million tickets sold that day against 3.5 million Verified Fan registrations (Confirmed [52]). Executive Order 14254 of 31 March 2025 directs the FTC to enforce the BOTS Act rigorously with state attorneys general and requires a joint report within 180 days (Confirmed [53]).

3.6 Buy now, pay later

The CFPB reported on 15 September 2022 that five lenders originated about 180 million buy-now-pay-later loans worth more than US$24 billion in 2021, close to tenfold growth since 2019, with 13.7 percent of loans having a return; its concerns were weak dispute rights and data harvesting, and fraud is not mentioned (Confirmed [54]). F5 Labs described the fraud side in August 2021: account takeover through phishing, credential stuffing and SIM cloning; new-account fraud with stolen or forged identities; and repaying the loans with stolen cards, which ends in merchant chargebacks (Reported [55]). The regulator's study and the security vendor's scenarios look at the same product from two sides, and only the vendor names fraud (Inferred).

3.7 Fake shops

SRLabs' BogusBazaar research, dated 5 August 2024 when opened, describes a fake-shop network that used more than 75,000 domains, about 22,500 active in April 2024, with more than a million orders since 2021, more than 850,000 victims mainly in Western Europe and the US, order volume over US$50 million, fake payment pages that harvest card data, semi-automated WooCommerce shop creation and a franchise model sold as fraud as a service (Reported [56]). Akamai reports one 2026 retail scam that ran more than 1,200 look-alike .shop domains on a single IP address, aged dormant domains before use, and stood up replacement sites within hours of takedown (Reported [47]). The FTC's 2024 Consumer Sentinel data rank Online Shopping and Negative Reviews fourth among all report categories and second among fraud categories (Confirmed [101]), and the FBI's Internet Crime Complaint Center counted 49,572 non-payment and non-delivery complaints with US$785.4 million lost in 2024 (Confirmed [103]).

Part 4: platform vulnerabilities and the KEV record

4.1 The commerce entries in KEV

CISA's KEV catalog, version 2026.11.10, lists six Adobe Commerce and Magento entries and none for WooCommerce, PrestaShop or Shopify; it also lists SAP Commerce Cloud CVE-2019-0344 and Sitecore CVE-2025-53690 (Experience Commerce among the affected products, added 4 Sep 2025) (Confirmed [23]).

CVE	Product	Weakness (NVD or KEV)	Severity and bulletin	NVD published	KEV added	Source
CVE-2022-24086	Adobe Commerce and Magento Open Source 2.4.3-p1, 2.3.7-p2 and earlier	CWE-20: improper input validation during checkout, unauthenticated code execution	CVSS 9.8, APSB22-12	16 Feb 2022	15 Feb 2022	[24][23]

CVE	Product	Weakness (NVD or KEV)	Severity and bulletin	NVD published	KEV added	Source
CVE-2024-34102 (CosmicSting)	Adobe Commerce 2.4.7 and earlier lines	CWE-611: XML external entity reference, leading to code execution	CVSS 9.8, APSB24-40	13 Jun 2024	17 Jul 2024	[25][23]
CVE-2025-54236 (SessionReaper)	Adobe Commerce	CWE-20: improper input validation enabling session takeover; KEV: customer account takeover via the REST API	CVSS 9.1, APSB25-88 (9 Sep 2025)	9 Sep 2025	24 Oct 2025	[27][23]
CVE-2026-48356 (PolyShell)	Adobe Commerce	CWE-434: unrestricted upload of file with dangerous type, no authentication	Adobe CVSS 9.6, NVD CVSS 9.3, APSB26-73	14 Jul 2026	27 Oct 2026	[31][32][23]
CVE-2026-71362	Adobe Commerce	CWE-863: incorrect authorization, privilege escalation	CVSS 9.1, APSB26-92	11 Aug 2026	24 Sep 2026	[33][23]
CVE-2026-75650	Adobe Commerce	CWE-1336: template engine injection, code execution	CVSS 10.0, APSB26-146	7 Sep 2026	8 Sep 2026	[34][23]
CVE-2019-0344	SAP Commerce Cloud	CWE-502	per KEV	not opened	30 Sep 2024	[23]
CVE-2025-53690	Sitecore (affected products include Sitecore Experience Commerce (XC))	CWE-502	per KEV	not opened	4 Sep 2025	[23]

CVE-2022-24086 entered KEV a day before NVD published it (Confirmed [23][24]). The two CVSS values for PolyShell differ: Adobe's bulletin gives 9.6, while the NVD record and press coverage give 9.3; this study uses the vendor's value for the vendor's product (Confirmed [31][32]; Inferred for the choice).

4.2 CosmicSting, 2024

Sansec reports that Adobe's fix shipped on 11 June 2024 at low priority; about 75 percent of stores were still unpatched on 18 June; attacks in the wild began on 23 June; Adobe raised the priority on 26 June; and stores were compromised at five to thirty an hour (Reported [26]). The typical chain stole the store's crypt key and then injected skimming JavaScript and fake payment forms into CMS blocks and content, so remediation required rotating the key as well as patching (Reported [26]). At least eight groups were active; Sansec attributes more than 2,000 compromised stores to one group by 14 October and about 3,000 more to another by 13 November 2024 (Reported [26]). KEV listed the CVE on 17 July, 24 days after the first reported attacks (Confirmed [23]; Reported [26]; the gap is Inferred).

4.3 SessionReaper, 2025

Adobe shipped APSB25-88 as an emergency patch on 9 September 2025 at priority 2 (Confirmed [27]; Reported [28]). Sansec reports that fewer than one in three stores had patched by 19 September, that the first attacks came on 22 October, that about 31 percent of Magento stores it watched were hit by 24 October and 49 percent by 26 October, with 16 to 18 percent backdoored, and that 81 percent had been visited by attackers by 1 November (Reported [28]). Adobe moved the bulletin to priority 1 on 24 October, the day CISA added it to KEV (Reported [28]; Confirmed [23]).

4.4 PolyShell and the CMS-block loader, 2026

PolyShell's full record, with lab-verified exposure and fix, is in Magento and Adobe Commerce, CVE-2026-48356: Lab-Verified Exposure and Fix; this paragraph summarizes it. Sansec disclosed PolyShell on 17 March 2026: an unrestricted file upload through the Magento REST API using a polyglot file, with no production patch at publication, and attacks seen against 79.5 percent of stores (Reported [29]). The fix shipped only in the 2.4.9 pre-release, and 2.4.9 was released on 12 May 2026 (Reported [29]). On 30 March a mass wave compromised 471 stores in one hour, uploading webshells and backdoors and then injecting an obfuscated JavaScript loader into CMS pages and blocks (Reported [30]). Adobe's production-line bulletin APSB26-73, dated 14 July 2026 at priority 2, fixes CVE-2026-48356 among 14 CVEs, rates it critical with no authentication required, and states that Adobe is not aware of exploits in the wild (Confirmed [31]). CISA added it to KEV on 27 October (Confirmed [23]). The bulletin's wording conflicts with Sansec's March reports by about four months (Inferred from [29][30][31]).

On 24 October 2026 Sansec reported a JavaScript loader stored in Magento CMS-block content on 953 stores since July 2025, mostly Magento; it served payloads only to real shoppers and nothing to scanners; earlier waves entered through PolyShell and SessionReaper; patched stores were also found infected; the newest domain sat on 83 stores, 60 of them earlier victims; and Sansec does not state that the final payload was a skimmer (Reported [35]). The Hacker News carried the same findings on 26 October, citing Sansec (Reported [36]). Re-infection of earlier victims is the pattern PCI SSC quoted in 2019 (Reported [67][35]; the link is Inferred).

4.5 WooCommerce, PrestaShop, Drupal Commerce

WooCommerce disclosed on 23 March 2023 a flaw in WooCommerce Payments found on 22 March through a HackerOne report; patched builds were pushed automatically with the WordPress.org Plugins Team, and after first finding no exploitation evidence it reported customer accounts of potential exploits by 27 March (Confirmed [38]). NVD records it as CVE-2023-28121, unauthenticated requests impersonating an administrator in versions through 5.6.1, CWE-287, CVSS 9.8 (Confirmed [37]). In 2026, NVD published CVE-2026-27540, an unrestricted file upload (CWE-434) in the WooCommerce Wholesale Lead Capture plugin through 2.0.3.1 (Confirmed [41]); Infosecurity Magazine, citing Wordfence, reports more than 100,000 blocked exploitation attempts peaking from 4 to 17 June 2026, with webshell installs, on a plugin with about 6,000 installs, fixed in 2.0.3.2 (Reported [42]).

PrestaShop CVE-2022-31181 is a SQL injection chainable to PHP eval in versions 1.6.0.10 to before 1.7.8.7, CWE-89 and CWE-74; CVE-2022-36408 was rejected as a duplicate of it (Confirmed [39]). CERT/CC's VU#385711 of 9 November 2026 describes PrestaShop's debug-mode settings being written into PHP configuration without escaping, so that an authenticated user with that permission can inject PHP (CVE-2026-124916); version 9.2.1 fixes it, and the note does not state whether exploitation was observed (Confirmed [40]). SecurityWeek reports that Drupal says the Commerce Core access bypass CVE-2026-118539, on more than 42,000 sites, is exploited in the wild, with a risk score of 21 of 25; Drupal's own advisory was not opened (Reported [43]).

4.6 What the platform record says

Every Adobe Commerce flaw in KEV allowed code execution, session takeover or privilege escalation on the store itself (Confirmed [23][24][25][27][32][33][34]). In each of the three dated waves, attackers moved faster than the vendor's priority rating, and each wave ended with code written into the store's own content (Reported [26][28][29][30]; Inferred for the pattern). The vulnerability-management lesson is the one Log4Shell taught on another platform: a KEV listing is a floor, and a fix without cleanup leaves the attacker's foothold in place (Inferred).

Part 5: the standards and regulatory record

5.1 PCI DSS, 2006 to 2025

The PCI Security Standards Council was founded in 2006 by American Express, Discover, JCB International, MasterCard and Visa Inc., which share ownership and governance equally (Confirmed [57]). PCI DSS v1.2 became generally available on 1 October 2008 with no new major requirements beyond the 12 in place since the Council's inception in September 2006, but with a June 2010 sunset for WEP wireless implementations (Confirmed [58]). That sunset was set two months after DOJ alleged the Gonzalez ring had entered retailers through their wireless networks, and took effect almost two years later (Confirmed [4][58]; the timing link is Inferred).

PCI SSC moved v4.0 to the first quarter of 2022 in June 2021 and said future-dated requirements would likely take effect 2.5 to 3 years after publication (Confirmed [59]). PCI DSS v4.0 was published on 31 March 2022, and v3.2.1 retired on 31 March 2024 (Confirmed [60]). PCI DSS v4.0.1, announced on 11 June 2024, added no requirements and deleted none; it added applicability notes on managing payment page scripts and left the effective dates unchanged (Confirmed [61]). PCI SSC said on 20 August 2024 that 51 of the 64 new v4.x requirements were future-dated and took effect on 31 March 2025 (Confirmed [62]). Requirements 6.4.3 (payment page script management) and 11.6.1 (change and tamper detection on payment pages) are among them: best practice from March 2022, required and assessed after 31 March 2025 (Confirmed [63]).

The information supplement of 10 March 2025, "Payment Page Security and Preventing E-Skimming", covers scripts being authorized, integrity-checked and monitored for tampering, and security-impacting HTTP headers; it says e-skimming has increased significantly as businesses rely more on external scripts, adds no requirements, and does not name Content Security Policy or Subresource Integrity; PCI SSC does not enforce compliance (Confirmed [66]). On 30 January 2025 PCI SSC removed 6.4.3, 11.6.1 and 12.3.1 from Self-Assessment Questionnaire A, effective 31 March 2025, and replaced them with an eligibility criterion that the merchant confirm its site is not susceptible to script attacks; the underlying requirements are unchanged (Confirmed [64]). FAQ 1588 of 28 February 2025 explains that criterion for SAQ A r1, effective 1 April 2025: the merchant can meet it with techniques like those of 6.4.3 and 11.6.1 or with confirmation from its compliant third-party service provider or processor, and it applies to merchants that embed a provider's payment page or form, not to full redirects (Confirmed [65]).

The 2011 Tokenization Guidelines say replacing the primary account number with tokens reduces cardholder data in scope but does not remove PCI DSS obligations, and controls still apply at the point of capture (Confirmed [69]). A browser skimmer reads the card number in the form before it is tokenized, so tokenization protects the stored number, not the checkout (Inferred from [69]).

5.2 EMV and 3-D Secure

Visa's roadmap expansion of 4 February 2013 required US ATM acquirer processors to support EMV chip data by 17 April 2015 and set a US ATM liability shift for 1 October 2017, after which the ATM acquirer bears counterfeit fraud cost (Confirmed [73]). The 1 October 2015 point-of-sale shift date was not checked against a card-brand primary. The FBI's PSA I-100815, revised 13 October 2015, said many US banks would have reissued chip cards by October 2015 and warned that EMV does not stop card-not-present fraud online or by telephone, and that magnetic-stripe data can still be stolen at terminals without EMV (Confirmed [72]).

PCI SSC released the PCI 3DS Core Security Standard around 25 October 2017 to cover the physical and logical security of the EMV 3-D Secure Access Control Server, Directory Server and 3DS Server; it supports EMVCo's protocol specification rather than replacing it (Confirmed [70]). Visa Secure is Visa's EMV 3-D Secure program; it exchanges data between merchant, issuer and, when needed, the consumer before authorization to help prevent card-not-present fraud, and Visa says it pioneered the original 3-D Secure protocol more than 15 years ago (Confirmed [71]). The EBA and ECB report that transactions authenticated with strong customer authentication show lower fraud rates and credit the PSD2 rules with reducing fraud (Confirmed [98]).

5.3 Regulators and courts

The UK record runs through the ICO: BA at GBP 20 million and Ticketmaster UK at GBP 1.25 million in 2020 (Confirmed [12][13]). The ICO fined DSG Retail GBP 500,000 in 2020 after a cyber attack affecting at least 14 million people; the Court of Appeal ruled for the ICO on 19 February 2026, and the proceedings ended on 7 October 2026 with DSG paying GBP 200,000 (Confirmed [74]). The US record runs through the FTC and the courts: the Wyndham opinion of 2015 and the settlement that wrote PCI DSS audits into a 20-year order (Confirmed [11][10]).

The SEC's disclosure guidance of 13 October 2011 said material cyber risks and incidents may need disclosure in risk factors, MD&A and financial statements, without disclosure that would itself compromise security (Confirmed [75]). On 26 July 2023 the SEC adopted Form 8-K Item 1.05, generally due four business days after a materiality determination, and Regulation S-K Item 106; 10-K disclosure applies to fiscal years ending on or after 15 December 2023, and 8-K disclosure from 18 December 2023 (Confirmed [76]). TJX's and Heartland's filings of 2007 and 2009 and Revolve's Item 8.01 filing of 2026, made under the new regime but not under Item 1.05, bracket that change (Confirmed [2][5][19]).

5.4 Europol's e-commerce actions

Europol's first European-wide action on e-commerce fraud led to 42 arrests of suspects who made more than 3,000 fraudulent online purchases worth EUR 3.5 million with stolen card data, in ten countries, coordinated by EC3 with card schemes, banks, logistics firms and merchants, after a UK action led by the DCPCU in June 2016 (Confirmed [77]). eCommerce Action 2017, 6 to 16 June 2017 across 26 countries, led to 76 arrests over more than 20,000 fraudulent transactions worth over EUR 5 million (Confirmed [78]). eComm 2018, 4 to 15 June 2018 across 28 countries, led to 95 arrests over more than 20,000 fraudulent card-not-present transactions worth over EUR 8 million, with almost 200 private partners, inspired by a UK pilot with Visa (Confirmed [79]). A Europol headline of 30 October 2019 reports 60 e-commerce fraudsters arrested in an international operation; only the headline and date were read (Confirmed [80]). The December 2023 digital skimming action, Part 3.1, turned from arrests to merchant notification (Confirmed [81]).

Part 6: the economics

6.1 Worldwide card fraud (Nilson, Reported)

Nilson's figures are worldwide gross losses to issuers, merchants and acquirers on all card channels, not e-commerce alone, and only the free excerpts were read.

Year	Worldwide gross card fraud	Rate per $100 of volume	Source
2016	$22.80 billion, up 4.4 percent	not stated in excerpt	[82]
2018	$27.85 billion	not stated in excerpt	[83]
2019	$28.65 billion, up 2.9 percent	6.78 cents	[83][84]
2020	$28.58 billion	6.81 cents	[84]
2021	$32.34 billion, up 13.8 percent	6.61 cents	[85][86]
2022	$33.45 billion	6.81 cents	[86]
2023	$33.83 billion; US-issued cards $14.32 billion on $13.007 trillion of US volume	6.58 cents	[87]
2024	dollar total subscriber-only (not checked); US cards tied to 41.87 percent of worldwide losses, "overwhelmingly" card-not-present; worldwide card volume $51.920 trillion	not checked	[88]

From 2016 to 2023 the worldwide total rose about 48 percent while the rate per $100 stayed between 6.58 and 6.81 cents in the years given (Reported [82][87]; the percentage is computed, Inferred).

6.2 What a dollar of fraud costs a merchant (LexisNexis, Reported)

LexisNexis Risk Solutions' True Cost of Fraud studies are vendor-sponsored surveys (Reported [92]). The 2022 study put the cost of each $1 of fraud at $3.85 for US e-commerce merchants and $3.45 for Canadian ones (Reported [89]). The 2023 study put it at about three times the lost transaction value on average, with segment figures of about $2.89 to $3.17 (Reported [90]). The 2024 study, published in 2025, put it at $4.61 for US merchants and $4.52 for Canadian ones, from 487 US and 82 Canadian companies, and charted a US series that starts at $2.40 in 2016 (Reported [91]). The 2026 study, from 513 executives, puts it at $5.13 in the US and $5.23 in Canada, the first time either passed $5; 37 percent of respondents were significantly hit by fraud-related revenue losses; more than half of US firms saw churn caused by anti-fraud friction; more than two thirds of fraud costs were domestic; and the study flags agentic commerce as a new exposure (Reported [92]). The 2023 study reports cybersecurity alerts in use at more than 60 percent of retail and about half of e-commerce businesses, and machine learning applied to pre-authorization fraud at between a third and half of merchants (Reported [90]).

6.3 Forecasts (Juniper, Reported)

Juniper Research forecast on 26 June 2023 that merchant losses to online payment fraud would exceed $362 billion globally from 2023 to 2028, $91 billion in 2028 alone (Reported [93]). On 27 October 2026 it forecast financial-institution spending on fraud prevention of $36.2 billion in 2026, rising to more than $66.2 billion by 2031 (Reported [94]). Both are model outputs, and the second covers financial institutions, not merchants.

6.4 Who pays (central banks and regulators, Confirmed)

The Federal Reserve's 2023 data on covered debit issuers put fraud losses to all parties at 17.6 basis points of transaction value, $17.63 per $10,000, up from 7.8 basis points in 2011 (Confirmed [95]). Merchants absorbed 49.9 percent of those losses (38.3 percent in 2011), issuers 28.3 percent (59.8 percent in 2011) and cardholders 21.8 percent (under 1.8 percent in 2011) (Confirmed [95]). Card-not-present fraud made up 54.3 percent of debit fraud losses, against 22.2 percent for lost and stolen cards, 17.5 percent for counterfeit and 5.9 percent other; merchants absorbed 65.1 percent of card-not-present losses, and the Fed attributes the rising merchant share largely to card-not-present growth, assuming acquirers pass every chargeback to merchants (Confirmed [95]). Fraud incidence more than tripled from 2011 to 2021 and flattened from 2021 to 2023 (Confirmed [95]). US card payments in 2024 were 187.7 billion transactions worth $11.50 trillion (Confirmed [97]).

The Fed's October 2018 study is the clearest measure of displacement: as chip cards spread, in-person card fraud fell from $3.68 billion in 2015 to $2.91 billion in 2016 while remote card fraud rose from $3.40 billion to $4.57 billion, and the 2016 remote fraud rate of 18.71 basis points was about twice the in-person 9.34 (Confirmed [96]).

The EBA and ECB report of August 2024 put reported payment fraud across the EEA at EUR 4.3 billion in 2022 and EUR 2.0 billion in the first half of 2023, with card fraud on EEA-issued cards at EUR 633 million in that half-year (Confirmed [98]). Remote card fraud was 82 percent of card fraud by value though remote payments were about 24 percent of card value; theft of card details drove 64 percent of remote card fraud by volume; fraud rates were about ten times higher where the counterpart sat outside the EEA; and 71 percent of card fraud by value was cross-border (Confirmed [98]). Users bore 45 percent of card fraud losses in that half-year, with national shares from 30 percent or less to 80 percent or more (Confirmed [98]).

US law sets the floor for cardholders. Regulation Z caps credit cardholder liability for unauthorized use at the lesser of $50 or the amount obtained before notice (Confirmed [99]). Regulation E sets debit liability at the lesser of $50 or the transfers before notice if reported within two business days, up to $500 if later, and potentially unlimited for transfers after 60 days from the statement (Confirmed [100]). That difference fits the Fed's finding that the cardholder share has grown in debit (Confirmed [95]; the link is Inferred).

6.5 What victims report

The FTC's Consumer Sentinel data show consumers reporting more than $12.5 billion in fraud losses in 2024, up 25 percent; Online Shopping and Negative Reviews was the fourth-largest category overall and second among fraud categories; credit cards were the payment method most often named, while bank transfers ($2.09 billion) and cryptocurrency ($1.42 billion) carried the largest losses (Confirmed [101][102]). The FBI's 2024 Internet Crime Report counts $16.6 billion in total reported losses, up 33 percent; Non-Payment/Non-Delivery at 49,572 complaints and $785.4 million (against $309.6 million in 2023 and $281.8 million in 2022); and Credit Card/Check Fraud at 12,876 complaints and $199.9 million (Confirmed [103]). Both are self-reported by victims and undercount (Inferred).

Part 7: the defender view

7.1 Payment page integrity

The control set the record supports has three layers. The first is knowing and authorizing every script: PCI DSS 6.4.3, and the library's Software Inventory and Asset Vulnerability Enumeration countermeasures (Confirmed [63][114]). The second is detecting change: PCI DSS 11.6.1, the file-integrity monitoring the ICO said would have caught BA's edit, and D3FEND's File Integrity Monitoring, defined as detecting suspicious changes to files (Confirmed [63][12][113]). The third is limiting what an altered script can do: the W3C's Content Security Policy Level 3, a defense-in-depth control over what a page can fetch or execute, whose section 8.6 says a policy can mitigate exfiltration through server allowlists but that a policy without default-src cannot, and a wildcard img-src allows exfiltration (Confirmed [105]); and Subresource Integrity, under which the browser checks a fetched script or stylesheet against an author-supplied hash and refuses to run a resource that fails, with cross-origin use needing CORS and Integrity-Policy headers able to block resources without integrity metadata (Confirmed [104]).

None of the three is complete. SRI cannot pin a script whose source changes by design, such as a chat bot or analytics tag, and a server-side injection writes the skimmer into the merchant's own first-party content, where CSP and SRI do not reach (Confirmed [104]; Reported [44][45]; Inferred for the combination). Cloudflare's polyfill.io rewrite stood down on responses with a CSP header, so even a defender's automatic fix depended on the merchant's policy (Reported [17]). The library has no D3FEND page for CSP or SRI (Demonstrated [114]).

7.2 Access and platform hygiene

Every remote path a supplier can use needs multi-factor authentication and session control: BA's Citrix gateway lacked it, Home Depot's attackers entered with a vendor's user name and password and then acquired elevated rights, and Backoff's operators brute-forced remote desktop logins (Confirmed [12][8][9]). For commerce platforms, the record supports patching on the KEV clock, rotating secrets after a key-disclosure flaw, removing webshells and searching content tables such as CMS blocks for injected code, because Sansec found patched stores still infected (Confirmed [23]; Reported [26][35]). Microsoft recommends patching the CMS and its plugins and checking web assets, and Sansec recommends server-side scanning, restricted admin access and two-factor authentication (Reported [45][44]). End-of-life platforms such as Magento 1 after June 2020 no longer receive vendor patches (Reported [14]; Inferred).

7.3 Logins, bots and card testing

The New York Attorney General ranks bot detection as the most effective defense against credential stuffing, followed by multi-factor authentication, passwordless sign-in, checks against compromised passwords and a web application firewall with rate limiting; it calls CAPTCHA less effective and recommends re-authentication at purchase (Confirmed [46]). Stripe's card-testing guidance adds velocity rules and protection of secret API keys (Confirmed [48]). ATT&CK's detection strategy DET0460 for Credential Stuffing looks for reused breached credentials across services (Confirmed [114]).

7.4 ATT&CK detection strategies the library carries

The library's ATT&CK data carries detection strategies DET0480 for Web Portal Capture (unauthorized changes to login-facing web files), DET0176 for Drive-by Compromise, DET0309 for Compromise Software Supply Chain, DET0460 for Credential Stuffing, DET0495 for Financial Theft and DET0264 for JavaScript (Confirmed [114][108]). DET0480 is the closest ATT&CK analytic to payment-page change detection, though it is written for login pages (Confirmed [108]; Inferred for the fit).

7.5 Disclosure and response

Two lessons recur. In most cases where the record says who noticed first, detection came from outside: Visa and MasterCard told Heartland, a third party told BA and Europol notified 443 merchants; a Twitter user's warning to Ticketmaster was dismissed; TJX is the exception, finding the software itself (Confirmed [5][12][13][81][3]). And disclosure is now a clock: SEC Item 1.05's four business days, BA's notice to the ICO the day after the alert, and the FTC's 10-day breach assessment in the Wyndham order (Confirmed [76][12][10]).

Part 8: MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0, the Center for Threat-Informed Defense's Fight Fraud Framework (F3) as the library carries it, CWE, CAPEC and D3FEND. Every ATT&CK id was checked against the library's data files on 11 November 2026, the FIN6, FIN8, T1056.003, T1189, T1195.002, T1110.004 and T1657 pages were opened on the live ATT&CK site, and every library page linked below exists in the `mitre/` tree (Confirmed [106][107][108][109][110][111][112][114]). The live pages opened carry ATT&CK v20.1; ids, names and tactics were matched against the library's v20.0 data, and none differ for the ids used here (Confirmed [106][114]). Except where the ATT&CK page itself carries the procedure (FIN6, FIN8, FIN7 and the point-of-sale software), the mappings are this study's reading of the advisories, filings and penalty notices (Inferred). No event in this study touches industrial control systems in the verified record, so there is no ATT&CK for ICS table.

ATT&CK Enterprise techniques

Tactic names follow ATT&CK v20.0, which splits the former Defense Evasion tactic into Stealth and Defense Impairment. Library sub-technique pages use a dash in the file name (`T1059-007.md`). The layer score column gives the Navigator layer's value for each technique (see Navigator layer below).

Id	Name	Tactic (v20.0)	Where it appears in the record	Source	Layer score
T1078	Valid Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	BA: a Swissport employee's credentials on the Citrix gateway (22 Jun 2018); Home Depot: a third-party vendor's user name and password (release of 6 Nov 2014); Target: HVAC contractor credentials (Reported, Nov 2013)	[12][8][7]	100
T1199	Trusted Relationship	Initial Access	The same three supplier paths into BA, Home Depot and Target	[12][8][7]	100
T1133	External Remote Services	Persistence, Initial Access	BA's Citrix Access Gateway without multi-factor authentication (Jun 2018)	[12]	100

Id	Name	Tactic (v20.0)	Where it appears in the record	Source	Layer score
T1110	Brute Force	Credential Access	Backoff operators brute-force remote desktop logins (TA14-212A, 31 Jul 2014)	[9]	100
T1021.001	Remote Desktop Protocol	Lateral Movement	Backoff access through remote desktop (TA14-212A)	[9]	100
T1055	Process Injection	Stealth, Privilege Escalation	Backoff injects into explorer.exe (TA14-212A)	[9]	100
T1056.001	Keylogging	Collection, Credential Access	Backoff keylogging (TA14-212A)	[9]	100
T1071.001	Web Protocols	Command and Control	Backoff's HTTP POST command and control (TA14-212A)	[9]	100
T1040	Network Sniffing	Credential Access, Discovery	Gonzalez ring's sniffer programs on card-processing networks and the Dave & Buster's packet sniffer (DOJ, 5 Aug 2008)	[4]	100
T1669	Wi-Fi Networks	Initial Access	Gonzalez ring "wardriving" into eight retailers' wireless networks (DOJ, 5 Aug 2008)	[4]	100
T1005	Data from Local System	Collection	FIN6 payment card data procedure, citing the BA and Newegg incidents; BA's plaintext card logs reached on 26 Jul 2018	[106][12]	100
T1119	Automated Collection	Collection	FIN6 script bound to the submit-payment button; point-of-sale collection	[106]	100
T1059.007	JavaScript	Execution	FIN6 malicious JavaScript stealing card data from e-commerce sites; BA's edited script (live 21 Aug to 5 Sep 2018); the Inbenta script on Ticketmaster UK's payment page (Feb to Jun 2018); CosmicSting skimmers in CMS blocks (2024, Reported); Convertr's tracker (Oct 2026, Reported)	[106][12][13][26][21]	100
T1048.003	Exfiltration Over Unencrypted Non-C2 Protocol	Exfiltration	FIN6 sends stolen card data by HTTP POST	[106]	100
T1056.003	Web Portal Capture	Collection, Credential Access	Capture of card fields in the shopper's browser at BA, Ticketmaster UK and Convertr; the ATT&CK page has no skimming procedure, so the id choice is this study's framing	[108][12][13][21]	40
T1195.002	Compromise Software Supply Chain	Initial Access	The Inbenta chat bot (2018), the polyfill.io domain (Feb to Jun 2024) and the Convertr tracker (Oct 2026); ATT&CK's procedures are build and update compromises such as SolarWinds, so the id choice is Inferred	[13][16][17][21][110]	40

Id	Name	Tactic (v20.0)	Where it appears in the record	Source	Layer score
T1189	Drive-by Compromise	Initial Access	polyfill.io redirecting mobile visitors of embedding sites (25 Jun 2024); the ATT&CK page covers tampered scripts but no skimming case	[16][17][109]	40
T1190	Exploit Public-Facing Application	Initial Access	The six Adobe Commerce/Magento KEV entries (2022 to 2026); Cardbleed's suspected remote code execution (Sep 2020, Reported); WooCommerce Wholesale Lead Capture (Jun 2026, Reported); Drupal Commerce Core (Oct 2026, Reported)	[23][24][25][27][32][33][34][14][42][43]	100
T1505.003	Web Shell	Persistence	PolyShell mass wave uploads webshells (30 Mar 2026); webshell installs through CVE-2026-27540 (Jun 2026)	[30][42]	60
T1027	Obfuscated Files or Information	Stealth	Obfuscated JavaScript injected into CMS pages and blocks (30 Mar 2026); obfuscated and spoofed-analytics skimmers (Microsoft, May 2022)	[30][45]	60
T1110.004	Credential Stuffing	Credential Access	More than 1.1 million accounts at 17 companies (NY OAG guide, undated); buy-now-pay-later account takeover (F5 Labs, Aug 2021, Reported)	[46][55][111]	100
T1074.001	Local Data Staging	Collection	ATT&CK's mappings for RawPOS, FrameworkPOS, PUNCHTRACK and PUNCHBUGGY; tied to no named incident in this study	[114]	40
T1657	Financial Theft	Impact	The CD Universe extortion demand (Dec 1999, Reported) and the Gonzalez ring's ATM cash-out (DOJ, 2008); the ATT&CK page names no e-commerce or skimming case	[1][4][112]	40

Point-of-sale RAM scraping has no single ATT&CK technique; Backoff's memory scraping is carried here only through the techniques TA14-212A names (Inferred). This study found no ATT&CK technique for card testing, scalping or fake shops in the library's data (Demonstrated [114]); they are mapped through F3 below.

ATT&CK groups and software

Object	Id and library page	Tie to this study	Source
FIN6	G0037	Associated names include Magecart Group 6, ITG08, Skeleton Spider, TAAL and Camouflage Tempest; procedures for JavaScript card theft from e-commerce sites, automated collection, card data from local systems (citing BA and Newegg) and HTTP POST exfiltration; page v4.0, modified 31 Jul 2026	[106][114]
FIN7	G0046	Point-of-sale malware, the Combi Security front company, big game hunting from 2020; also listed among T1195.002 procedure examples	[110][114]
FIN8	G0061	Hospitality and retail from at least January 2016; switched from point-of-sale targeting to ransomware in June 2021	[107]
FIN5	G0053	User of RawPOS in ATT&CK	[114]
FrameworkPOS	S0503	FIN6's point-of-sale malware for physical POS systems	[106][114]
RawPOS	S0169	Point-of-sale malware in use since at least 2008	[114]
Pillowmint	S0517	FIN7's point-of-sale malware for card capture	[114]
PUNCHTRACK	S0197	FIN8's non-persistent point-of-sale scraper	[114]
PUNCHBUGGY	S0196	FIN8 backdoor seen on point-of-sale networks in hospitality	[114]

In the library's ATT&CK data the word Magecart appears once, as the FIN6 alias; no software, campaign or technique object mentions Magecart or skimming (Demonstrated [114]). Backoff, BlackPOS, the polyfill.io operation and the Magento waves have no ATT&CK object and are left unlinked (Confirmed [114]). The ATT&CK page for T1195.002 lists APT41 (G0096) and the SolarWinds campaign among its build-compromise examples, covered in the library's APT41 study and SolarWinds SUNBURST study (Confirmed [110]).

F3 fraud techniques

The library carries the Center for Threat-Informed Defense's Fight Fraud Framework under `data/fraud/` with pages under `mitre/f3/` (Demonstrated [114]). The pairings below are this study's (Inferred).

F3 id	Name (library data)	Where it appears in the record	Source
F1011	Card Dump Capture	Point-of-sale scraping at Target, Home Depot and Backoff victims; browser skimming at BA and Ticketmaster UK	[7][8][9][12][13][114]
F1012	Card Testing	Stripe's definition; Akamai's fake accounts for card testing	[48][47][114]
F1006 and F1006.002	Account Takeover; Account Takeover: Exposed Login Credential	Credential stuffing at retailers and food delivery (NY OAG); buy-now-pay-later takeover (F5 Labs)	[46][55][114]
T1110.004	Brute Force: Credential Stuffing (F3's ATT&CK-derived entry, under Initial Access)	Same	[46][114]

F3 id	Name (library data)	Where it appears in the record	Source
F1002.002	Abuse of Public-Facing API: Web API Abuse	Automated ticket buying under the BOTS Act cases; bot traffic in the Eras Tour onsale	[51][52][114]
F1020.002	Create Fake Materials: Fake Website	BogusBazaar's fake shops; Akamai's look-alike .shop domains	[56][47][114]
F1001	3DS Bypass	No incident in the opened record; listed because 3-D Secure is the card-not-present control in Part 5.2	[114]
T1583.008	Acquire Infrastructure: Malvertising	F3 describes ads leading to card skimming; no incident in the opened record	[114]

CWE and CAPEC

Weakness or pattern	Name (library data)	Who assigns it	Use here	Source
CWE-20	Improper Input Validation	NVD and KEV, for CVE-2022-24086 and CVE-2025-54236	Checkout code execution and session takeover in Adobe Commerce	[24][27][23]
CWE-611	Improper Restriction of XML External Entity Reference	NVD, for CVE-2024-34102	CosmicSting	[25]
CWE-434	Unrestricted Upload of File with Dangerous Type	Adobe, NVD and KEV, for CVE-2026-48356; NVD for CVE-2026-27540	PolyShell; WooCommerce Wholesale Lead Capture	[31][32][41]
CWE-863	Incorrect Authorization	NVD, for CVE-2026-71362	Adobe Commerce privilege escalation	[33]
CWE-1336	Improper Neutralization of Special Elements Used in a Template Engine	NVD, for CVE-2026-75650	Adobe Commerce code execution	[34]
CWE-502	Deserialization of Untrusted Data	KEV, for SAP CVE-2019-0344 and Sitecore CVE-2025-53690	SAP Commerce Cloud; Sitecore Experience Commerce	[23]
CWE-287	Improper Authentication	NVD, for CVE-2023-28121	WooCommerce Payments	[37]
CWE-89 and CWE-74	Improper Neutralization of Special Elements used in an SQL Command; Improper Neutralization of Special Elements in Output Used by a Downstream Component	NVD, for CVE-2022-31181	PrestaShop	[39]
CWE-799 and CWE-837	Improper Control of Interaction Frequency; Improper Enforcement of a Single, Unique Action	OWASP, for OAT-001 Carding and OAT-008 Credential Stuffing	Card testing and credential stuffing	[49][50]
CWE-532	Insertion of Sensitive Information into Log File	Not assigned by any record; present in the library's data	BA's plaintext card logs (Inferred binding)	[12][114]
CAPEC-650	Upload a Web Shell to a Web Server	Library data maps it to T1505.003	PolyShell and CVE-2026-27540 webshell installs (Inferred binding)	[30][42][114]
CAPEC-600	Credential Stuffing	Library data maps it to T1110.004 (related CWE-522, CWE-307 and others)	Part 3.3	[114]
CAPEC-186	Malicious Software Update	Library data maps it to T1195.002 (CWE-494)	Third-party scripts altered at source (Inferred binding)	[114]
CAPEC-112	Brute Force	Library data maps it to T1110	Backoff's remote desktop brute force (Inferred binding)	[9][114]

Weakness or pattern	Name (library data)	Who assigns it	Use here	Source
CAPEC-560	Use of Known Domain Credentials	Library data maps it to T1078	Supplier credentials at BA and Home Depot (Inferred binding)	[12][8][114]
CAPEC-66	SQL Injection	Library data lists it for CWE-89	PrestaShop CVE-2022-31181 (Inferred binding)	[39][114]
CAPEC-115	Authentication Bypass	Library data lists it for CWE-287	WooCommerce Payments CVE-2023-28121 (Inferred binding)	[37][114]

Three patterns are left out on purpose. The library's CWE-611 record lists only CAPEC-221, a denial-of-service pattern that does not describe CosmicSting's use; its CWE-434 record lists only CAPEC-1, an access-control pattern; and CAPEC-210, which OWASP cites for carding and credential stuffing, is not in the library's CAPEC data (Demonstrated [114]; Confirmed [49][50]). The library has no generated CWE pages; the CWE Reference and CAPEC Reference cover the classes.

D3FEND countermeasures

Countermeasure	Id	Library mapping to this study's techniques in `technique_to_d3fend.json`	The record it matches	Source
File Integrity Monitoring	D3-FIM	T1005, T1071.001, T1074.001, T1119, T1505.003	The ICO's PCI DSS 10.5.5 and 11.5 finding at BA; PCI DSS 11.6.1. The live D3FEND page does not list T1056.003 or T1059.007	[114][113][12][63]
Software Inventory	D3-SWI	T1056.003, T1195.002	PCI DSS 6.4.3 script inventory (Inferred pairing)	[114][63]
Asset Vulnerability Enumeration	D3-AVE	T1056.003, T1195.002	Knowing which platform version is exposed to a KEV entry (Inferred pairing)	[114][23]
Software Update	D3-SU	T1056.003, T1195.002	Patching Adobe Commerce and plugins (Inferred pairing)	[114][23]
Restore Software	D3-RS	T1056.003, T1195.002	Cleaning CMS content after the Magento waves (Inferred pairing)	[114][35]
Connection Attempt Analysis	D3-CAA	T1110.004, T1199	Credential stuffing and supplier logins	[114][46]
User Geolocation Logon Pattern Analysis	D3-UGLPA	T1021.001, T1048.003, T1071.001, T1110.004, T1189, T1190, T1199	Same	[114]
Network Traffic Filtering	D3-NTF	T1021.001, T1048.003, T1071.001, T1110.004, T1189, T1190, T1199	Keeping remote desktop and supplier paths off the card network (Inferred pairing)	[114][9]
Outbound Traffic Filtering	D3-OTF	T1048.003, T1071.001	Server-side egress control against card exfiltration; the browser-side counterpart, CSP, has no D3FEND page	[114][105]
Inbound Traffic Filtering	D3-ITF	T1190	Filtering exploit traffic to commerce platforms	[114]
Session Termination	D3-ST	T1133, T1199, T1021.001	Ending supplier and remote-desktop sessions	[114]
Executable Allowlisting and Process Spawn Analysis	D3-EAL, D3-PSA	T1505.003	Stopping and spotting webshells after PolyShell	[114][30]
URL Reputation Analysis and Homoglyph Detection	D3-URA, D3-HD	T1189	polyfill.io's look-alike analytics domain; look-alike fake-shop domains (Inferred pairing)	[114][16][47]
Multi-factor Authentication	D3-MFA	T1110.001 to T1110.003 only; not T1110.004, T1078 or T1133	BA's gateway without MFA; NY OAG's second-ranked defense. The library's mapping does not reach the techniques where the record most needs it	[114][12][46]

The mappings in the third column are the library's data (Demonstrated [114]); pairing each countermeasure with the record is this study's reading (Inferred). T1059.007 and T1657 map to no D3FEND technique in the

library, and no D3FEND technique covers Content Security Policy or Subresource Integrity (Demonstrated [114]). The library's D3FEND pages are listed in the D3FEND Reference.

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, navigator/library-layers/ecommerce-threats.json, listed on the Navigator layers page. It is pinned to ATT&CK v20 and scores each technique by the strength of the record behind it: 100 where a Confirmed primary (a DOJ release, a US-CERT alert, an ICO penalty notice, a company filing or release, a KEV or NVD record, or ATT&CK's own FIN6 procedures) describes the behavior; 60 where the behavior is known only from Reported vendor research (the PolyShell webshells and obfuscated loaders); and 40 where the id choice itself stretches the record (Web Portal Capture, Compromise Software Supply Chain and Drive-by Compromise for skimming and third-party scripts, Local Data Staging for the point-of-sale families, and Financial Theft). Each entry's comment names the source numbers above. The F3 matrix the library ships is navigator/fraud/f3-matrix.json.

Cross-cutting themes

- **The attacker follows the data to where it is readable.** Stored and encrypted card files gave way to memory scraping on terminals and then to the checkout form in the browser, and chip cards pushed fraud into the card-not-present channel (Confirmed [3][9][12][96]; Inferred for the arc). See the Fraud Framework Reference.
- **Your suppliers are your perimeter.** Supplier credentials opened BA, Home Depot and, by press accounts, Target, and supplier code reached the payment pages of Ticketmaster UK and of the brands whose checkouts Convertr runs (Confirmed [12][8][13]; Reported [7][21]). See the Supply Chain Security Reference and Identity and Access Management Reference.
- **Platform monoculture concentrates risk.** One platform accounts for six of the eight commerce-related entries in KEV, and Sansec's figures for the share of stores probed run to 81 percent in a single wave (Confirmed [23]; Reported [28]). See the Vulnerability Prioritization Reference.
- **Detection mostly comes from outside the merchant.** Card brands, a third party, Europol and a security vendor's crawler found most of the breaches in this record; TJX found its own (Confirmed [5][12][81][3]; Reported [29]). See the Incident Response Reference.
- **Standards trail incidents by years.** WEP's sunset followed the wireless intrusions, and script integrity on payment pages became mandatory more than six and a half years after BA (Confirmed [58][4][63][12]; Inferred for the gap). See the Regulatory Landscape Reference and the GRC and Compliance Reference.
- **The browser is the new point of sale.** CSP, SRI and integrity monitoring are the controls, and each has a documented gap (Confirmed [104][105]; Reported [44][45]). See the Browser Security Reference and the Web Application Security Reference.

What is overstated and what is understated

- **Overstated: "every skimmer is Magecart".** ATT&CK ties the name only to FIN6's alias Magecart Group 6; PCI SSC, Microsoft and Sansec use it as an umbrella for many groups (Confirmed [106]; Reported [68][45][44]). A Magecart label on a new incident says what happened, not who did it (Inferred).

- **Overstated: CSP or SRI as the answer to skimming.** Sansec put about 64 percent of a 2022 sample server-side, where browser policies do not reach, and CSP Level 3 itself names the configurations that still allow exfiltration (Reported [44]; Confirmed [105]).
- **Overstated: "PCI compliance prevents skimming".** The ICO found that requirements already in PCI DSS v3.2.1 would have caught BA's change, and the payment-page requirements were best practice, not mandatory, until March 2025 (Confirmed [12][63]).
- **Overstated: EMV "ended card fraud".** The FBI said in 2015 that chips do not protect card-not-present transactions, and the Fed measured remote fraud rising as in-person fraud fell (Confirmed [72][96]).
- **Overstated: the single headline number.** The 40 million card numbers of the Gonzalez case, Target's 40 million cards and 70 million customers, and Home Depot's 53 million email addresses count different things at different stages of disclosure (Confirmed [4][7][8]). Sansec's store percentages are one vendor's crawler telemetry, and every industry loss figure in Part 6 is a vendor survey, a paywalled excerpt or a forecast (Reported [26][28][82][92][93]).
- **Overstated: Target's root-cause story.** The HVAC vendor, BlackPOS and the ignored FireEye alerts all come from press accounts that the Senate staff report relays and says it relies on (Reported [7]).
- **Overstated: regulator fines as deterrence.** BA's penalty fell from GBP 183.39 million proposed to GBP 20 million, and DSG's from GBP 500,000 to a GBP 200,000 payment after about six years (Confirmed [12][74]).
- **Understated: vendor bulletins lag exploitation.** CosmicSting shipped at low priority, SessionReaper at priority 2, and APSB26-73 reported no known exploits months after mass exploitation (Reported [26][28][29]; Confirmed [31]).
- **Understated: re-infection.** Patched stores stay infected, earlier victims are hit again, and PCI SSC quoted re-infection within days as early as 2019 (Reported [35][67]).
- **Understated: the merchant as the unknowing point of compromise.** Europol's 2023 action was a notification exercise for 443 merchants, and SAQ A merchants self-attest that their sites are safe from script attacks (Confirmed [81][64]).
- **Understated: small-merchant skimming that is never reported.** Sansec's count of more than 70,000 compromised stores by 2022 far exceeds the regulator cases on record; no primary source opened gives a reporting rate, so the size of the gap is not checked (Reported [44]; Inferred).
- **Understated: the cardholder's rising share.** US debit cardholders bore under 1.8 percent of fraud losses in 2011 and 21.8 percent in 2023, and EEA users bore 45 percent in the first half of 2023 (Confirmed [95][98]).

Sources

All sources were opened on 11 November 2026. Sources are grouped by topic: the breach record [1] to [22], platform vulnerabilities [23] to [43], threat classes [44] to [56], standards and regulation [57] to [81], economics [82] to [103], and the controls, MITRE record and library data [104] to [114]. Grades apply to the source as used here.

#	Source	URL	Opened	Grade
1	WIRED, Hacker posts credit card info, Jan 2000 (citing The New York Times)	wired.com/2000/01/hacker-posts-credit-card-info/	2026-11-11	Reported
2	The TJX Companies, Form 8-K, filed 18 Jan 2007	https://www.sec.gov/Archives/edgar/data/109198/000095013507000226/0000950135-07-000226.txt	2026-11-11	Confirmed
3	The TJX Companies, Form 10-K for fiscal 2007, filed Mar 2007	https://www.sec.gov/Archives/edgar/data/109198/000095013507001906/b64407tje10vk.htm	2026-11-11	Confirmed
4	US DOJ, release 08-689, retail hacking ring charged, 5 Aug 2008	justice.gov/archive/opa/pr/2008/August/08-ag-689.html	2026-11-11	Confirmed
5	Heartland Payment Systems, Form 8-K with exhibits, 20 Jan 2009	https://www.sec.gov/Archives/edgar/data/1144354/000136231009000509/0001362310-09-000509.txt	2026-11-11	Confirmed
6	Heartland Payment Systems, Exhibit 99.1, Heartland and Visa settlement, 8 Jan 2010	https://www.sec.gov/Archives/edgar/data/0001144354/000119312510003149/dex991.htm	2026-11-11	Confirmed
7	US Senate Committee on Commerce, Science and Transportation, majority staff report, A Kill Chain Analysis of the 2013 Target Data Breach, 26 Mar 2014	commerce.senate.gov/services/files/24d3c229-...	2026-11-11	Confirmed (Target's confirmations); Reported (the press accounts it relays)
8	The Home Depot, news release, 6 Nov 2014	ir.homedepot.com/news-releases/2014/11-06-2014-014517315	2026-11-11	Confirmed
9	US-CERT, Alert TA14-212A, Backoff Point-of-Sale Malware, 31 Jul 2014	cisa.gov/news-events/alerts/2014/07/31/backoff-point-sale-malware	2026-11-11	Confirmed
10	FTC, Wyndham settles FTC charges, 9 Dec 2015	https://www.ftc.gov/news-events/news/press-releases/2015/12/wyndham-settles-ftc-charges-it-unfairly-placed-consumers-payment-card-information-risk	2026-11-11	Confirmed
11	US Court of Appeals, Third Circuit, FTC v. Wyndham Worldwide Corp., No. 14-3514, 24 Aug 2015	www2.ca3.uscourts.gov/opinarch/143514p.pdf	2026-11-11	Confirmed
12	UK ICO, Penalty Notice to British Airways, 16 Oct 2020	ico.org.uk/media2/migrated/2618421/ba-penalty-20201016.pdf	2026-11-11	Confirmed
13	UK ICO, Penalty Notice to Ticketmaster UK Limited, 13 Nov 2020	ico.org.uk/media2/migrated/2618609/ticketmaster-uk-limited-mpn.pdf	2026-11-11	Confirmed
14	Sansec, Largest Magento hack to date ("Cardbleed"), Sep 2020	sansec.io/research/largest-magento-hack-to-date	2026-11-11	Reported
15	Cloudflare, polyfill.io now available on cdnjs, 29 Feb 2024	blog.cloudflare.com/polyfill-io-now-available-on-cdnjs-...	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
16	Sansec, Polyfill supply chain attack, 25 Jun 2024 (updated to 28 Jun)	sansec.io/research/polyfill-supply-chain-attack	2026-11-11	Reported
17	Cloudflare, Automatically replacing polyfill.io links with Cloudflare's mirror, 26 Jun 2024	blog.cloudflare.com/automatically-replacing-polyfill-io-links-...	2026-11-11	Confirmed (Cloudflare's own data and action); Reported (the sale date, earliest file and usage estimate)
18	NVD, CVE-2024-38526	nvd.nist.gov/vuln/detail/CVE-2024-38526	2026-11-11	Confirmed
19	Revolve Group, Form 8-K, filed 30 Oct 2026	https://www.sec.gov/Archives/edgar/data/1746618/000119312526439022/rvlv-20261029.htm	2026-11-11	Confirmed
20	The Record, fashion retailer data breach involving payment cards, 30 Oct 2026	therecord.media/resolve-fashion-retailer-data-breach-payment-cards	2026-11-11	Reported
21	Sansec, Convertr Plausible supply chain attack, 26 Oct 2026 (updated 27 Oct)	sansec.io/research/convertr-plausible-supply-chain-attack	2026-11-11	Reported
22	The Register, Japanese homeware company pulls online store after cloud breach, 9 Nov 2026	theregister.com/cyber-crime/2026/11/09/japanese-homeware-giant-...	2026-11-11	Reported
23	CISA, Known Exploited Vulnerabilities catalog, version 2026.11.10 (catalog page and JSON feed)	cisa.gov/known-exploited-vulnerabilities-catalog and the JSON feed	2026-11-11	Confirmed
24	NVD, CVE-2022-24086	nvd.nist.gov/vuln/detail/CVE-2022-24086	2026-11-11	Confirmed
25	NVD, CVE-2024-34102 (record and API)	nvd.nist.gov/vuln/detail/CVE-2024-34102	2026-11-11	Confirmed
26	Sansec, CosmicSting research	sansec.io/research/cosmicsting	2026-11-11	Reported
27	NVD, CVE-2025-54236	nvd.nist.gov/vuln/detail/CVE-2025-54236	2026-11-11	Confirmed
28	Sansec, SessionReaper research	sansec.io/research/sessionreaper	2026-11-11	Reported
29	Sansec, Magento PolyShell, 17 Mar 2026	sansec.io/research/magento-polyshell	2026-11-11	Reported
30	Sansec, PolyShell mass attack wave, 30 Mar 2026	sansec.io/research/polyshell-mass-attack-wave	2026-11-11	Reported
31	Adobe, Security bulletin APSB26-73 for Adobe Commerce, 14 Jul 2026	https://www.adobe.com/trust/security/products/commerce/apsb26-73.html	2026-11-11	Confirmed
32	NVD, CVE-2026-48356	nvd.nist.gov/vuln/detail/CVE-2026-48356	2026-11-11	Confirmed
33	NVD, CVE-2026-71362	nvd.nist.gov/vuln/detail/CVE-2026-71362	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
34	NVD, CVE-2026-75650	nvd.nist.gov/vuln/detail/CVE-2026-75650	2026-11-11	Confirmed
35	Sansec, Magento CMS block loader (deepveindrilling), 24 Oct 2026	sansec.io/research/magento-cms-block-loader-deepveindrilling	2026-11-11	Reported
36	The Hacker News, 953 online stores infected, 26 Oct 2026 (citing Sansec)	thehackernews.com/2026/10/hackers-infect-953-online-stores-with.html	2026-11-11	Reported
37	NVD, CVE-2023-28121	nvd.nist.gov/vuln/detail/CVE-2023-28121	2026-11-11	Confirmed
38	WooCommerce developer blog, Critical vulnerability detected in WooCommerce Payments, 23 Mar 2023 (updated 27 Mar)	developer.woocommerce.com/2023/03/23/critical-vulnerability-...	2026-11-11	Confirmed
39	NVD, CVE-2022-31181	nvd.nist.gov/vuln/detail/CVE-2022-31181	2026-11-11	Confirmed
40	CERT/CC, Vulnerability Note VU#385711, 9 Nov 2026	kb.cert.org/vuls/id/385711	2026-11-11	Confirmed
41	NVD, CVE-2026-27540	nvd.nist.gov/vuln/detail/CVE-2026-27540	2026-11-11	Confirmed
42	Infosecurity Magazine, WooCommerce Wholesale Lead Capture exploitation, Sep 2026 (citing Wordfence)	infosecurity-magazine.com/news/woocommerce-wholesale-lead-capture/	2026-11-11	Reported
43	SecurityWeek, Drupal Commerce Core vulnerability exploited against online stores, Oct 2026	securityweek.com/drupal-commerce-core-vulnerability-...	2026-11-11	Reported
44	Sansec, What is Magecart	sansec.io/what-is-magecart	2026-11-11	Reported
45	Microsoft Security Blog, Beneath the surface: uncovering the shift in web skimming, 23 May 2022	microsoft.com/en-us/security/blog/2022/05/23/beneath-the-surface-...	2026-11-11	Reported
46	New York State Attorney General, Business Guide for Credential Stuffing Attacks (undated page)	ag.ny.gov/publications/business-guide-credential-stuffing-attacks (also served at ag.ny.gov/business-guide-credential-stuffing-attacks)	2026-11-11	Confirmed
47	Help Net Security, on the Akamai Fraud and Abuse Report 2026, 30 Oct 2026	helpnetsecurity.com/2026/10/30/akamai-fake-account-abuse-report/	2026-11-11	Reported
48	Stripe documentation, Card testing	docs.stripe.com/disputes/prevention/card-testing	2026-11-11	Confirmed
49	OWASP Automated Threats to Web Applications, OAT-001 Carding	owasp.github.io/.../OAT-001_Carding	2026-11-11	Confirmed
50	OWASP Automated Threats to Web Applications, OAT-008 Credential Stuffing	owasp.github.io/.../OAT-008_Credential_Stuffing	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
51	FTC, FTC brings first-ever cases under the BOTS Act, 22 Jan 2021	`https://www.ftc.gov/news-events/news/press-releases/2021/01/ftc-brings-first-ever-cases-under-bots-act`	2026-11-11	Confirmed
52	Ticketmaster, Taylor Swift The Eras Tour onsale explained, 19 Nov 2022	business.ticketmaster.com/press-release/taylor-swift-the-eras-tour-onsale-explained/	2026-11-11	Confirmed
53	The White House, Executive Order 14254, Combating Unfair Practices in the Live Entertainment Market, 31 Mar 2025	whitehouse.gov/presidential-actions/2025/03/combating-unfair-practices-...	2026-11-11	Confirmed
54	CFPB, study details the rapid growth of buy now, pay later lending, 15 Sep 2022	consumerfinance.gov/archive/newsroom/cfpb-study-details-...	2026-11-11	Confirmed
55	F5 Labs, Fraud scenarios in the buy now pay later ecosystem, 5 Aug 2021	f5.com/labs/articles/fraud-scenarios-in-the-buy-now-pay-later-ecosystem	2026-11-11	Reported
56	SRLabs, BogusBazaar (page dated 5 Aug 2024 when opened)	srlabs.de/blog/bogusbazaar	2026-11-11	Reported
57	PCI Security Standards Council, About us	pcisecuritystandards.org/about_us/	2026-11-11	Confirmed
58	PCI SSC, press release on PCI DSS v1.2, 30 Sep 2008 (availability 1 Oct 2008)	listings.pcisecuritystandards.org/pdfs/pr_080930_PCIDSSv1-2.pdf	2026-11-11	Confirmed
59	PCI SSC blog, Updated PCI DSS v4.0 timeline, 17 Jun 2021	blog.pcisecuritystandards.org/updated-pci-dss-v4.0-timeline	2026-11-11	Confirmed
60	PCI SSC, press release on PCI DSS v4.0, 31 Mar 2022	pcisecuritystandards.org/about_us/press_releases/pr_03312022	2026-11-11	Confirmed
61	PCI SSC blog, Just published: PCI DSS v4.0.1, 11 Jun 2024	blog.pcisecuritystandards.org/just-published-pci-dss-v4-0-1	2026-11-11	Confirmed
62	PCI SSC blog, Now is the time to adopt the future-dated requirements of PCI DSS v4.x, 20 Aug 2024	blog.pcisecuritystandards.org/now-is-the-time-...	2026-11-11	Confirmed
63	PCI SSC blog, Coffee with the Council: guidance for PCI DSS e-commerce requirements effective after 31 March 2025, 26 Mar 2025	blog.pcisecuritystandards.org/coffee-with-the-council-podcast-...	2026-11-11	Confirmed
64	PCI SSC blog, Important updates for merchants validating to SAQ A, 30 Jan 2025	blog.pcisecuritystandards.org/important-updates-...	2026-11-11	Confirmed
65	PCI SSC blog, FAQ clarifies new SAQ A eligibility criteria, 28 Feb 2025	blog.pcisecuritystandards.org/faq-clarifies-new-saq-a-eligibility-criteria-...	2026-11-11	Confirmed
66	PCI SSC blog, New information supplement: Payment Page Security and Preventing E-Skimming, 10 Mar 2025	blog.pcisecuritystandards.org/new-information-supplement-...	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
67	PCI SSC and RH-ISAC, The threat of online skimming to payment security, 1 Aug 2019	blog.pcisecuritystandards.org/the-threat-of-online-skimming-to-payment-security	2026-11-11	Confirmed (the bulletin); Reported (the re-infection figure it quotes)
68	PCI SSC blog, Online skimming and payment security, 9 Jan 2020	blog.pcisecuritystandards.org/online-skimming-and-payment-security	2026-11-11	Reported
69	PCI SSC, PCI DSS Tokenization Guidelines v2.0, Aug 2011	pcisecuritystandards.org/documents/Tokenization_Guidelines_Info_Supplement.pdf	2026-11-11	Confirmed
70	PCI SSC blog, What to know about the new PCI 3DS Core Security Standard, Oct 2017	blog.pcisecuritystandards.org/what-to-know-about-the-new-pci-3ds-core-security-standard	2026-11-11	Confirmed
71	Visa, Visa Secure product page (undated)	visa.com/en-us/products/visa-secure	2026-11-11	Confirmed
72	FBI IC3, PSA I-100815, revised 13 Oct 2015	ic3.gov/PSA/2015/PSA151008.pdf	2026-11-11	Confirmed
73	Visa, press release on the expanded US EMV roadmap, 4 Feb 2013	usa.visa.com/about-visa/newsroom/press-releases.releaseId.1780934.html	2026-11-11	Confirmed
74	UK ICO, ICO wins Court of Appeal case in DSG Retail ruling, Feb 2026 (with the Oct 2026 conclusion)	ico.org.uk/about-the-ico/media-centre/news-and-blogs/2026/02/ico-wins-court-of-appeal-case-in-dsg-retail-ruling/	2026-11-11	Confirmed
75	SEC Division of Corporation Finance, CF Disclosure Guidance Topic No. 2, 13 Oct 2011	`https://www.sec.gov/divisions/corpfin/guidance/cfguidance-topic2.htm`	2026-11-11	Confirmed
76	SEC, press release 2023-139, cybersecurity disclosure rules, 26 Jul 2023	`https://www.sec.gov/news/press-release/2023-139`	2026-11-11	Confirmed
77	Europol, First European-wide action on e-commerce fraud sees arrest of 42, Oct 2016	europol.europa.eu/media-press/newsroom/news/first-european-wide-action-...	2026-11-11	Confirmed
78	Europol, 76 arrested during second international action on e-commerce fraud, Jun 2017	europol.europa.eu/media-press/newsroom/news/76-arrested-...	2026-11-11	Confirmed
79	Europol, 95 e-commerce fraudsters arrested in international operation, Jun 2018	europol.europa.eu/media-press/newsroom/news/95-e-commerce-fraudsters-...	2026-11-11	Confirmed
80	Europol, 60 e-commerce fraudsters busted during international operation, 30 Oct 2019 (headline and date only)	europol.europa.eu/media-press/newsroom/news/60-e-commerce-fraudsters-...	2026-11-11	Confirmed
81	Europol, Action against digital skimming reveals 443 compromised online merchants, 22 Dec 2023	europol.europa.eu/media-press/newsroom/news/action-against-digital-skimming-...	2026-11-11	Confirmed
82	The Nilson Report, Card fraud losses reach $22.80 billion, Issue 1118, Oct 2017 (excerpt)	nilsonreport.com/articles/card-fraud-losses-reach-22-80-billion/	2026-11-11	Reported

#	Source	URL	Opened	Grade
83	The Nilson Report, Card fraud losses reach $28.65 billion, Issue 1187, Dec 2020 (excerpt)	nilsonreport.com/articles/card-fraud-losses-reach-28-65-billion/	2026-11-11	Reported
84	The Nilson Report, Card fraud losses dip to $28.58 billion, Issue 1209, Dec 2021 (excerpt)	nilsonreport.com/articles/card-fraud-losses-dip-to-28-58-billion/	2026-11-11	Reported
85	The Nilson Report, Card fraud losses worldwide, Issue 1232, Dec 2022 (excerpt)	nilsonreport.com/articles/card-fraud-losses-worldwide/	2026-11-11	Reported
86	The Nilson Report, Card fraud losses worldwide, Issue 1254, Dec 2023 (excerpt)	nilsonreport.com/articles/card-fraud-losses-worldwide-2/	2026-11-11	Reported
87	The Nilson Report, Card fraud losses worldwide in 2023, Issue 1276, Dec 2024 (excerpt)	nilsonreport.com/articles/card-fraud-losses-worldwide-in-2023/	2026-11-11	Reported
88	The Nilson Report, Issue 1298, Dec 2025 (excerpt on the site's search page)	nilsonreport.com/?s=card+fraud+losses	2026-11-11	Reported
89	LexisNexis Risk Solutions, True Cost of Fraud 2022, retail and e-commerce, North America	risk.lexisnexis.com/-/media/files/../lnrs_true_cost_of_fraud_retail_ecommercev3-2022_...pdf	2026-11-11	Reported
90	LexisNexis Risk Solutions, True Cost of Fraud 2023, retail and e-commerce, North America	risk.lexisnexis.com/-/media/files/../lnrs-2023-true-cost-of-fraud-study-...pdf	2026-11-11	Reported
91	LexisNexis Risk Solutions, True Cost of Fraud 2024 (published 2025), retail and e-commerce, North America	risk.lexisnexis.com/-/media/files/../lnrs-true_cost_of_fraud-study-retail_and_ecommerce-...pdf	2026-11-11	Reported
92	LexisNexis Risk Solutions, True Cost of Fraud 2026, retail and e-commerce	risk.lexisnexis.com/-/media/files/migrate/.../lexisnexis-true cost of fraud-study 2026 retail-ecommerce.pdf	2026-11-11	Reported
93	Juniper Research, Losses from online payment fraud to exceed $362 billion, 26 Jun 2023	juniperresearch.com/press/losses-online-payment-fraud-exceed-362-billion/	2026-11-11	Reported
94	Juniper Research, Financial institutions to spend over $66bn on fraud prevention, 27 Oct 2026	juniperresearch.com/press/financial-institutions-spend-over-66bn-fraud-prevention/	2026-11-11	Reported
95	Federal Reserve Board, 2023 Interchange Fee Revenue, Covered Issuer Costs, and Covered Issuer and Merchant Fraud Losses	federalreserve.gov/paymentsystems/2023-interchange-fee.htm	2026-11-11	Confirmed
96	Federal Reserve, Changes in U.S. Payments Fraud from 2012 to 2016, Oct 2018	federalreserve.gov/publications/files/changes-in-us-payments-fraud-from-2012-to-2016-20181016.pdf	2026-11-11	Confirmed
97	Federal Reserve Payments Study, 2015 to 2024 topline	federalreserve.gov/paymentsystems/frps_cy2015_24_topline.htm	2026-11-11	Confirmed
98	EBA and ECB, 2024 Report on Payment Fraud, Aug 2024	ecb.europa.eu/press/intro/publications/pdf/ecb.ebaecb202408.en.pdf	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
99	CFPB, Regulation Z, 12 CFR 1026.12	consumerfinance.gov/rules-policy/regulations/1026/12/	2026-11-11	Confirmed
100	CFPB, Regulation E, 12 CFR 1005.6	consumerfinance.gov/rules-policy/regulations/1005/6/	2026-11-11	Confirmed
101	FTC, Consumer Sentinel Network Data Book 2024	`https://www.ftc.gov/system/files/ftc_gov/pdf/csn-annual-data-book-2024.pdf`	2026-11-11	Confirmed
102	FTC, New FTC data show a big jump in reported losses to fraud, 10 Mar 2025	`https://www.ftc.gov/news-events/news/press-releases/2025/03/new-ftc-data-show-big-jump-reported-losses-fraud-125-billion-2024`	2026-11-11	Confirmed
103	FBI IC3, 2024 Internet Crime Report	ic3.gov/AnnualReport/Reports/2024_IC3Report.pdf	2026-11-11	Confirmed
104	W3C, Subresource Integrity (Working Draft SRI-2), 20 Mar 2026	w3.org/TR/SRI/	2026-11-11	Confirmed
105	W3C, Content Security Policy Level 3 (Working Draft), 27 Oct 2026	w3.org/TR/CSP3/	2026-11-11	Confirmed
106	MITRE ATT&CK, FIN6 (G0037), v4.0, modified 31 Jul 2026	attack.mitre.org/groups/G0037/	2026-11-11	Confirmed
107	MITRE ATT&CK, FIN8 (G0061)	attack.mitre.org/groups/G0061/	2026-11-11	Confirmed
108	MITRE ATT&CK, T1056.003 Web Portal Capture, v1.1, modified 12 May 2026	attack.mitre.org/techniques/T1056/003/	2026-11-11	Confirmed
109	MITRE ATT&CK, T1189 Drive-by Compromise, v1.7	attack.mitre.org/techniques/T1189/	2026-11-11	Confirmed
110	MITRE ATT&CK, T1195.002 Compromise Software Supply Chain, v1.1	attack.mitre.org/techniques/T1195/002/	2026-11-11	Confirmed
111	MITRE ATT&CK, T1110.004 Credential Stuffing, v1.7, modified 12 May 2026	attack.mitre.org/techniques/T1110/004/	2026-11-11	Confirmed
112	MITRE ATT&CK, T1657 Financial Theft, v1.2, modified 4 Nov 2026	attack.mitre.org/techniques/T1657/	2026-11-11	Confirmed
113	MITRE D3FEND, D3-FIM File Integrity Monitoring	d3fend.mitre.org/technique/d3f:FileIntegrityMonitoring/	2026-11-11	Confirmed
114	TeamStarWolf library data: `data/attack/groups.jsonl`, `software.jsonl`, `software_profiles.jsonl`, `software_to_technique.jsonl`, `technique_profiles.jsonl`, `detection_strategies.jsonl`, `technique_to_d3fend.jsonl`, `d3fend_countermeasures.jsonl`, `data/weaknesses/cwe.jsonl`, `capec.jsonl`, `data/fraud/f3_techniques.jsonl`, the `mitre/` tree and `case-studies/`	github.com/TeamStarWolf/TeamStarWolf/tree/main/data and the mitre tree	2026-11-11	Confirmed (Demonstrated where this study counted or searched the data)

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

Licensed under the Apache License, Version 2.0. Copyright © The MITRE Corporation. The Center for Threat-Informed Defense is a non-profit, privately funded research and development organization operated by MITRE Engenuity. https://ctid.mitre.org/ · https://github.com/center-for-threat-informed-defense

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Threat Actors, Malware Families, Notable Incidents
- Fraud Framework Reference, Regulatory Landscape Reference, GRC and Compliance Reference
- Web Application Security Reference, Browser Security Reference, API Security Reference, Supply Chain Security Reference
- Vulnerability Management Reference, Vulnerability Prioritization Reference, Vulnerability Root Causes, Incident Response Reference, Identity and Access Management Reference
- Related studies: The Dot-Com Era, 1994 to 2003, Magento and Adobe Commerce, CVE-2026-48356, Cybercrime and Hacktivism in Four Books, npm Supply Chain Attacks, PHP2Shell and the October 2026 Attack Wave, Log4Shell, SolarWinds SUNBURST, APT41: The Public Record, The Year 2019 in Intrusions, The Year 2020 in Intrusions, The Year 2021 in Intrusions, The Year 2024 in Intrusions, Case study timeline
- Groups and software: G0037 FIN6, G0046 FIN7, G0061 FIN8, G0053 FIN5, S0503 FrameworkPOS, S0169 RawPOS, S0517 Pillowmint, S0197 PUNCHTRACK, S0196 PUNCHBUGGY
- Techniques: T1059.007 JavaScript, T1056.003 Web Portal Capture, T1195.002 Compromise Software Supply Chain, T1190 Exploit Public-Facing Application, T1505.003 Web Shell, T1078 Valid Accounts, T1199 Trusted Relationship, T1133 External Remote Services, T1110.004 Credential Stuffing, T1005 Data from Local System, T1048.003 Exfiltration Over Unencrypted Non-C2 Protocol, T1040 Network Sniffing, T1669 Wi-Fi Networks, T1657 Financial Theft
- F3: F1011 Card Dump Capture, F1012 Card Testing, F1006 Account Takeover, F1020.002 Fake Website
- CAPEC: CAPEC-650 Upload a Web Shell to a Web Server, CAPEC-600 Credential Stuffing, CAPEC-186 Malicious Software Update
- Navigator layers, including this study's layer, ecommerce-threats.json